

HANDOUT PESERTA DIKLAT

Modul 4.4: Perancangan Sistem Keamanan & Keterlacakan Terintegrasi

Program Penguatan Kompetensi Tata Kelola Kearsipan
Level 4 (Mastery) – Manajemen Atas

PT PLN (Persero) – Pusat Pendidikan dan Pelatihan



LOGO PLN

Dokumen ini dirancang sebagai panduan mandiri dan workshop. Kompilasi dengan
pdflatex/xelatex.

Petunjuk Penggunaan Handout

Ikon & Konvensi Visual

Handout ini menggunakan beberapa konvensi visual untuk memudahkan navigasi:

- **Boks biru** seperti ini berisi ringkasan strategis, panduan tata kelola, atau template kebijakan yang menjadi perhatian utama Manajemen Atas.
- **Boks hijau** berjudul “Output Portofolio” menandakan tugas yang harus dikerjakan dan dikumpulkan sebagai bukti kompetensi.
- **Tabel** menyajikan matriks, rubrik penilaian, dan data terstruktur – gunakan sebagai referensi cepat.
- **Diagram TikZ/gambar** mengilustrasikan konsep kunci – setiap diagram disertai caption multi-baris dengan penjelasan dan sumber.
- **Catatan kaki** (footnote) berisi sitasi regulasi dan standar menggunakan format Chicago 17th edition.

Cara Menggunakan Handout Ini

1. **Sebelum pelatihan:** Baca Pendahuluan (bab tanpa nomor) untuk memahami konteks, target kompetensi, dan arsitektur keamanan terintegrasi. Gunakan Glosarium di akhir dokumen sebagai referensi istilah teknis.
2. **Saat pelatihan:** Ikuti pembahasan Bab 1–4 secara berurutan (kumulatif). Kerjakan Aktivitas Workshop di setiap bab (30 menit/bab). Hasil workshop menjadi bagian dari Portofolio yang dinilai.
3. **Studi kasus integratif:** Bab 5 menguji pemahaman holistik – baca skenario kebocoran arsip kontrak dan analisis dari 4 perspektif pilar keamanan.
4. **Setelah pelatihan:** Lihat Bab 6 (Validasi & Rubrik Penilaian) untuk memahami kriteria kelulusan dan menyusun komitmen tindak lanjut.

Catatan: Seluruh materi dalam handout ini dirancang agar dapat dipahami secara mandiri oleh Manajemen Atas tanpa perlu membaca Modul 4.1–4.3. Istilah teknis yang belum familiar dapat ditemukan di Glosarium di bagian akhir dokumen.

Daftar Isi

Pendahuluan	4
A Konteks & Urgensi: Mengapa Ini Penting bagi PLN?	4
B Target Kompetensi	4
C Sasaran & Prasyarat Peserta	5
D Arsitektur Keamanan Terintegrasi	6
1 Kontrol Akses Berbasis Peran (RBAC) Terintegrasi	9
1.1 Integrasi Konseptual dengan Sistem Kepegawaian	10
1.2 Matriks Role × Klasifikasi Arsip PLN	10
1.3 Langkah-Langkah Perancangan Skema RBAC	10
1.4 Aktivitas Workshop (30 Menit)	12
2 Mekanisme Audit Trail Otomatis & Keterlacakan	13
2.1 Kerangka 4W & Field Metadata Wajib	14
2.2 Kategori Event Audit Level Bisnis	14
2.3 Langkah-Langkah Perancangan Mekanisme Audit Trail	14
2.4 Aktivitas Workshop (30 Menit)	17
3 Kebijakan Keamanan Terintegrasi dengan ISMS	18
3.1 Integrasi dengan ISO/IEC 27001:2022	18
3.2 Tiga Prinsip Fundamental Kebijakan	21
3.3 Integrasi GCG BUMN (TARIF)	22
3.4 Langkah-Langkah Perumusan Kebijakan Keamanan	24
3.5 Template Kerangka Kebijakan Keamanan Arsip Digital	25
3.6 Aktivitas Workshop (30 Menit)	26
4 Sistem Backup & Disaster Recovery Terintegrasi	27
4.1 Strategi Backup 3-2-1 untuk Arsip PLN	27
4.2 Penetapan RTO & RPO Berbasis Criticality	28
4.3 Business Continuity Plan (BCP) Kearsipan	30
4.3.1 Analisis Dampak Bisnis (BIA) untuk Arsip Digital	32
4.3.2 Langkah-Langkah Perancangan Sistem Backup/DR	32
4.4 Aktivitas Workshop (30 Menit)	33
5 Studi Kasus Terintegrasi: Insiden Kebocoran Arsip Kontrak	35
5.1 Skenario	35
5.2 Analisis Berbasis Empat Pilar Keamanan	35
5.2.1 Pilar 1: Kontrol Akses – Apakah RBAC Berfungsi?	35
5.2.2 Pilar 2: Audit Trail – Apakah Audit Trail Berfungsi?	35
5.2.3 Pilar 3: Kebijakan Keamanan – Apakah Kebijakan Keamanan Memadai?	35
5.2.4 Pilar 4: Pemulihan Data – Apakah Backup/DR Berfungsi?	36
5.3 Pelajaran untuk Manajemen Atas	36
6 Validasi, Portofolio & Executive Tollgate	37
6.1 Ringkasan Kriteria Penilaian	37
6.2 Rubrik Penilaian Terukur	37
6.3 Executive Tollgate Verifikasi	37

Glosarium	41
Daftar Pustaka	43

Pendahuluan

Modul 4.4 merupakan mata pelajaran penutup dalam Level 4 (Mastery) yang berfokus pada perancangan tata kelola keamanan, integritas, dan keterlacakan arsip digital. Sasaran utamanya adalah membekali Manajemen Atas PLN dengan kemampuan merancang sistem keamanan yang terintegrasi penuh dengan kebijakan korporasi, regulasi nasional, dan prinsip GCG BUMN.

Dua konsep kunci yang menjadi landasan modul ini perlu dipahami sejak awal. Pertama, **Aset Informasi Kritis** adalah informasi yang kehilangan, kerusakan, atau pengungkapannya dapat menimbulkan dampak serius terhadap kelangsungan operasional, kepatuhan regulasi, atau reputasi organisasi. Dalam konteks PLN, aset informasi kritis mencakup kontrak pembangkit, laporan keuangan teraudit, dokumen RUPS, dan data pelanggan. Kedua, **Klasifikasi Arsip** adalah pengelompokan arsip berdasarkan tingkat sensitivitas dan dampak keamanannya. Modul ini menggunakan empat tingkat klasifikasi yang selaras dengan regulasi nasional dan praktik korporasi PLN: **Vital** (kerusakan berdampak nasional), **Rahasia** (kerusakan berdampak regional/unit), **Terbatas** (kerusakan berdampak operasional terbatas), dan **Publik** (tidak ada dampak signifikan).

A Konteks & Urgensi: Mengapa Ini Penting bagi PLN?

PLN sebagai Badan Usaha Milik Negara yang mengelola infrastruktur kelistrikan nasional menghadapi tantangan keamanan arsip digital yang semakin kompleks. Data Badan Siber dan Sandi Negara (BSSN) mencatat total anomali trafik serangan siber di Indonesia mencapai 1,63 miliar kejadian pada tahun 2021¹ dan meningkat menjadi 3,64 miliar hanya dalam periode Januari–Juli 2025², dengan BUMN menjadi salah satu target utama. Dalam konteks kearsipan, risiko ini bukan hanya soal teknis – melainkan soal akuntabilitas hukum dan kepatuhan regulasi.

Pertimbangkan skenario berikut: jika kontrak pembangkit senilai triliunan rupiah bocor karena akses tidak terkontrol, atau jika arsip vital menghilang tanpa audit trail yang dapat mempertanggungjawabkan siapa yang mengaksesnya kapan, maka PLN menghadapi risiko ganda: (1) kerugian finansial dan operasional akibat kehilangan aset informasi kritis, serta (2) sanksi regulasi dari OJK, BPK, ANRI, dan lembaga pengawas lainnya. Dalam perspektif GCG, kegagalan menjaga keamanan dan keterlacakan arsip secara langsung memengaruhi penilaian tata kelola perusahaan – termasuk dalam parameter TARIF yang menjadi tolok ukur kinerja BUMN.

Modul ini dirancang untuk menjawab kebutuhan tersebut dengan pendekatan empat pilar terintegrasi: Kontrol Akses (TK-1), Audit Trail (TK-2), Kebijakan Keamanan (TK-3), dan Backup/Disaster Recovery (TK-4). Studi kasus nyata di Bab 5 akan mendemonstrasikan bagaimana kegagalan pada satu pilar dapat menyebabkan kerentanan sistemik yang berdampak langsung pada operasional dan reputasi PLN.

B Target Kompetensi

Setelah menyelesaikan modul ini, peserta diharapkan mampu mencapai empat kompetensi utama yang dipetakan terhadap kriteria penilaian sebagai berikut:

Keempat target kompetensi di atas bersifat kumulatif dan terintegrasi: keberhasilan pencapaian pada setiap kompetensi menjadi prasyarat efektivitas kompetensi berikutnya. Misalnya,

¹Kompas.com, *BSSN Sebut Ada 1,6 Miliar Serangan Siber Selama 2021*, 7 Maret 2022.

²Tempo.co, *BSSN Catat 3,64 Miliar Serangan Siber di Indonesia Setengah Tahun Ini*, 29 Juli 2025.

Tabel 1: Pemetaan Target Kompetensi terhadap Kriteria Penilaian

Kode	Target Kompetensi	Kriteria Penilaian
TK-1	Peserta mampu merancang skema kontrol akses terintegrasi berbasis peran (RBAC) yang menghubungkan sistem kearsipan dengan sistem kepegawaian.	4.4.1
TK-2	Peserta mampu merancang mekanisme audit trail otomatis yang merekam setiap akses dan perubahan arsip.	4.4.2
TK-3	Peserta mampu merumuskan kebijakan keamanan yang terintegrasi dengan sistem manajemen keamanan informasi organisasi.	4.4.3
TK-4	Peserta mampu merancang sistem backup dan disaster recovery terintegrasi.	4.4.4

skema RBAC yang dirancang pada TK-1 akan menentukan siapa yang tercatat dalam audit trail (TK-2), yang pada gilirannya menjadi input kebijakan keamanan (TK-3) dan memengaruhi prioritas backup (TK-4).

C Sasaran & Prasyarat Peserta

- Target: Manajemen Atas (Unit Kearsipan, IT Governance, GCG, Risk Management)
- Prasyarat: Lulus Modul 4.3, memahami klasifikasi arsip dasar, familiar dengan sistem SAP (sistem perencanaan sumber daya perusahaan) dan Single Sign-On (SSO) organisasi
- Output: 4 dokumen portofolio kebijakan/prosedur siap validasi manajemen, masing-masing membuktikan pencapaian TK-1 hingga TK-4

Modul 4.4 berdiri di atas fondasi yang dibangun oleh tiga modul sebelumnya dalam Level 4. Tabel 2 merangkum cakupan masing-masing modul dan kaitannya dengan Modul 4.4:

Tabel 2: Ringkasan Modul 4.1–4.3 dan Kaitannya dengan Modul 4.4

Modul	Judul & Cakupan Utama	Relevansi dengan Modul 4.4
4.1	Merancang Potensi Integrasi Sistem, Prosedur, dan Teknologi Kearsipan Eksisting. Peserta mampu merancang peta kondisi eksisting, matriks potensi integrasi, dan skenario integrasi terpadu.	Menyediakan pemetaan aset dan sistem yang menjadi objek perlindungan keamanan dalam Modul 4.4.
4.2	Perancangan Arsitektur Sistem Terintegrasi. Peserta mampu merancang diagram arsitektur, titik integrasi antar subsistem (penciptaan, penggunaan, pemeliharaan, penyusutan), dan spesifikasi teknis/fungsional.	Menyediakan arsitektur sistem yang menjadi infrastruktur bagi kontrol keamanan (RBAC, audit trail) dalam Modul 4.4.
4.3	Optimalisasi Prosedur dan Alur Kerja Terintegrasi. Peserta mampu mengevaluasi prosedur eksisting, merancang alur kerja baru, dan menganalisis potensi peningkatan efektivitas.	Menyediakan prosedur dan alur kerja operasional yang harus dilindungi oleh kebijakan keamanan dalam Modul 4.4.

Ketiga modul tersebut menjadi prasyarat karena Modul 4.4 tidak membahas desain arsitektur teknis (ranah 4.2) atau optimalisasi alur kerja bisnis (ranah 4.3) secara langsung, melainkan berfokus pada lapisan tata kelola keamanan yang memastikan arsip digital PLN terlindungi, terlacak, dan tersedia.

D Arsitektur Keamanan Terintegrasi

Keempat target kompetensi dalam modul ini tidak berdiri sendiri, melainkan membentuk satu sistem tata kelola keamanan arsip yang saling terkait. Pemahaman terhadap hubungan antar-TK menjadi kunci bagi Manajemen Atas untuk mengarahkan tim secara koheren dan menghindari solusi parsial yang tidak saling mendukung.

Tabel 3: Hubungan Terintegrasi antar Target Kompetensi

TK	Terhubung dengan	Bentuk Integrasi
TK-1 (RBAC)	TK-2, TK-3	Matriks peran menentukan WHO yang tercatat di audit trail (TK-2) dan menjadi input penetapan kewenangan dalam kebijakan (TK-3).
TK-2 (Audit Trail)	TK-1, TK-3, TK-4	Log audit membuktikan kepatuhan RBAC (TK-1), menjadi bukti kepatuhan ISMS (TK-3), dan log operasi backup sendiri harus di-audit (TK-4).
TK-3 (Kebijakan ISMS)	TK-1, TK-2, TK-4	Kebijakan menjadi payung hukum bagi RBAC (TK-1), menetapkan standar audit (TK-2), dan menentukan kebijakan retensi-/recovery (TK-4).
TK-4 (Backup/DR)	TK-2, TK-3	Backup melindungi log audit trail (TK-2) dan merupakan kontrol wajib dalam kerangka ISMS (TK-3).

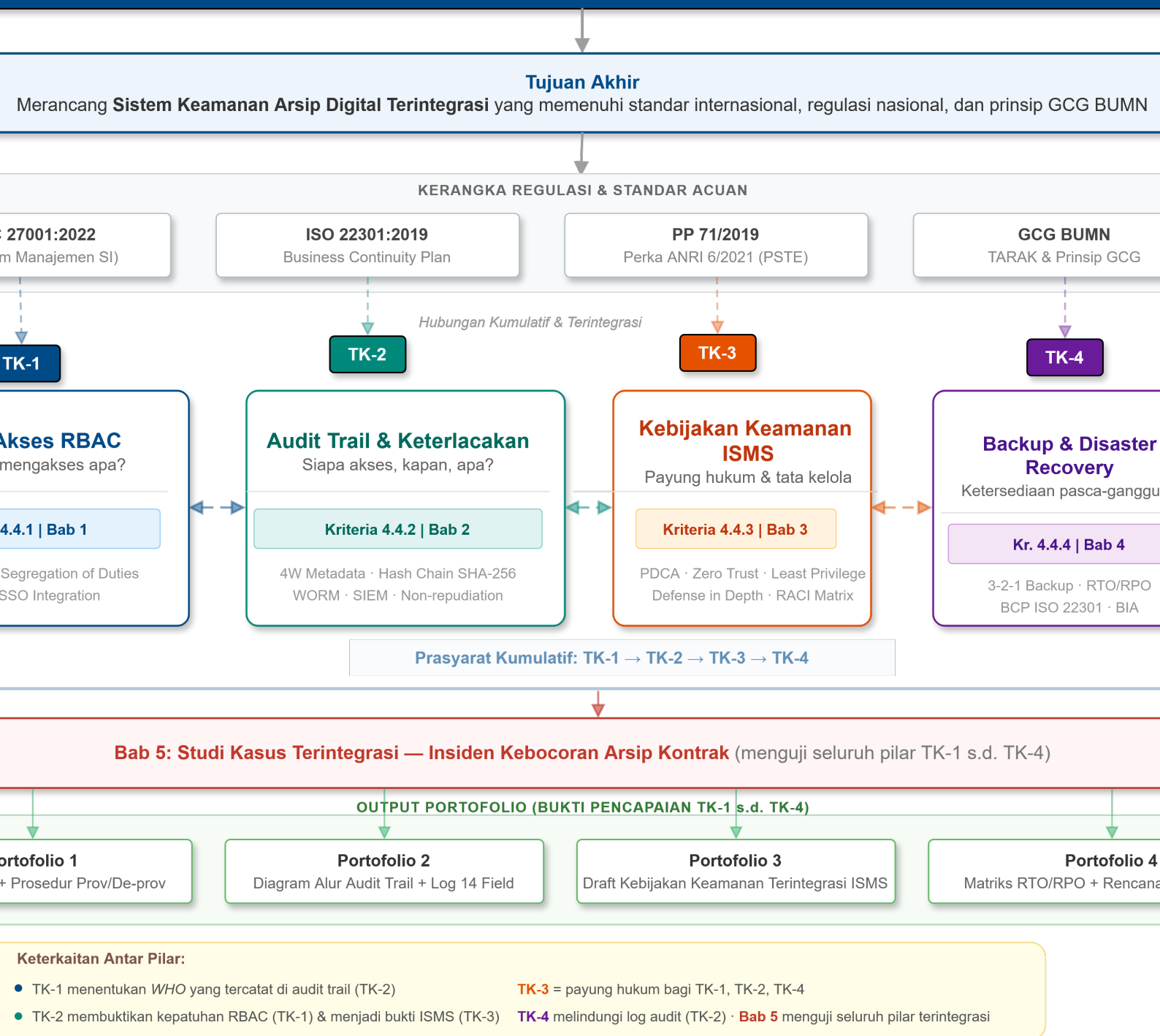
Pandangan Strategis untuk Manajemen Atas

Ketika mengesahkan kebijakan keamanan arsip, Manajemen Atas harus memastikan bahwa keempat pilar ini dirancang secara bersamaan, bukan secara berurutan oleh unit yang berbeda tanpa koordinasi. Solusi parsial – misalnya implementasi RBAC tanpa audit trail, atau backup tanpa kebijakan retensi – akan menciptakan celah keamanan yang tidak terdeteksi hingga terjadi insiden. Studi kasus di Bab 5 akan mendemonstrasikan bagaimana keempat pilar ini saling bergantung dalam situasi nyata.

Gambar 1 merupakan peta jalan yang menjawab pertanyaan sentral: “Bagaimana materi Modul 4.4 disusun sehingga mampu memenuhi seluruh target kompetensi dan kriteria penilaian?” Diagram ini menunjukkan bahwa modul ini dirancang dengan pendekatan empat pilar kumulatif: (1) TK-1 (Bab 1) – Kontrol Akses RBAC yang menjawab pertanyaan siapa yang boleh mengakses arsip; (2) TK-2 (Bab 2) – Audit Trail yang menjawab pertanyaan kapan dan apa yang dilakukan terhadap arsip; (3) TK-3 (Bab 3) – Kebijakan Keamanan ISMS yang menjadi payung hukum bagi seluruh kontrol; dan (4) TK-4 (Bab 4) – Backup/Disaster Recovery yang menjamin ketersediaan arsip pasca-gangguan.

Setiap pilar didukung oleh kerangka regulasi dan standar di baris atas: ISO/IEC 27001:2022

Kerangka Berpikir — Modul 4.4: Keamanan & Keterlacakan Terintegrasi



Gambar 1: Kerangka Berpikir Modul 4.4 – Pemetaan Struktur Materi terhadap Target Kompetensi dan Kriteria Penilaian

Diagram ini menunjukkan bagaimana keempat bab (Bab 1–4) dirancang secara kumulatif dan terintegrasi untuk memenuhi kriteria penilaian 4.4.1 s.d. 4.4.4, berlandaskan kerangka regulasi nasional dan standar internasional, serta di-capstone oleh Studi Kasus (Bab 5) yang menguji pemahaman holistik peserta.

(ISMS)³, ISO 22301:2019 (Business Continuity)⁴, PP 71/2019⁵ dan Perka ANRI 6/2021⁶ (kearsipan nasional), serta prinsip GCG BUMN/TARIF⁷. Garis penghubung antar-pilar menunjukkan bahwa keempat pilar bersifat kumulatif – keberhasilan pada pilar sebelumnya menjadi prasyarat efektivitas pilar berikutnya. Bab 5 (Studi Kasus) di bagian bawah menjadi titik integrasi yang menguji apakah peserta mampu menerapkan seluruh pilar secara sinergis dalam situasi insiden nyata. Keempat Portofolio di baris paling bawah merupakan bukti pencapaian kompetensi yang menjadi dasar penilaian.

³ISO/IEC 27001:2022, *Information Security Management Systems – Requirements*, 3rd ed. (Geneva: ISO, 2022).

⁴ISO 22301:2019, *Business Continuity Management Systems – Requirements*, 2nd ed. (Geneva: ISO, 2019).

⁵PP 71/2019, *Penyelenggaraan Sistem dan Transaksi Elektronik*, LNRI 196 (2019).

⁶Perka ANRI 6/2021, *Pengelolaan Arsip Elektronik*, BNRI 541 (2021).

⁷Permen BUMN PER-2/MBU/03/2023, *Pedoman GCG Signifikan BUMN*, BNRI 274 (2023).

Bab 1

Kontrol Akses Berbasis Peran (RBAC) Terintegrasi

(Kriteria Penilaian 4.4.1)

Bab ini mendukung pencapaian Pilar 1: Kontrol Akses – peserta mampu merancang skema kontrol akses terintegrasi berbasis peran (RBAC) yang menghubungkan sistem kearsipan dengan sistem kepegawaian. RBAC bukan sekadar matriks izin, melainkan kerangka tata kelola yang menghubungkan identitas kepegawaian dengan hak akses arsip secara otomatis. Tiga prinsip fundamental yang mendasari RBAC perlu dipahami oleh Manajemen Atas:

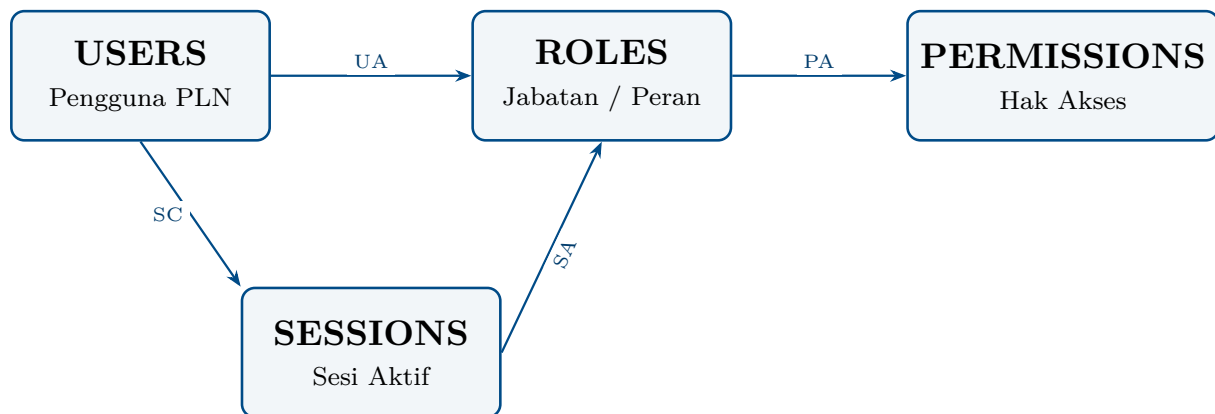
Least Privilege (hak akses minimum) adalah prinsip yang menyatakan bahwa setiap pengguna atau sistem hanya boleh diberikan hak akses yang benar-benar diperlukan untuk menjalankan tugasnya – tidak lebih. Dalam konteks kearsipan PLN, prinsip ini berarti bahwa staf administrasi tidak perlu memiliki hak Ekspor terhadap arsip Rahasia jika tugasnya hanya memerlukan hak Read. Penerapan *least privilege* meminimalkan luasnya dampak jika terjadi insiden keamanan, karena penyerang atau pengguna yang kompromikan hanya memiliki akses terbatas.

Segregation of Duties (pemisahan fungsi) adalah prinsip yang memastikan tidak ada satu peran yang memiliki kombinasi hak akses yang berlebihan sehingga menciptakan potensi konflik kepentingan atau celah pengawasan. Dalam kearsipan, ini berarti pemisahan antara hak membuat arsip (Create), menyetujui arsip (Approve), dan mengekspor arsip (Export) ke peran yang berbeda. Tanpa segregation of duties, satu orang dapat secara mandiri menciptakan, menyetujui, dan mengekspor dokumen tanpa mekanisme keseimbangan pengawasan.

Prosedur Darurat (*break-glass procedure*) adalah mekanisme yang memungkinkan akses khusus di luar hak akses normal dalam situasi darurat, dengan catatan bahwa setiap penggunaan prosedur darurat dicatat secara lengkap dalam audit trail dan memerlukan persetujuan serta eskalasi pascakejadian. Dalam konteks PLN, prosedur darurat digunakan ketika arsip Vital harus diakses di luar jam kerja untuk menangani insiden kritis, dengan persetujuan atasan langsung yang terdokumentasi.

Dalam perspektif keterlacakan (traceability), RBAC memainkan peran fundamental: tanpa kontrol akses yang terstruktur, tidak mungkin menjamin bahwa setiap jejak digital dalam audit trail benar-benar merepresentasikan tindakan pihak yang berwenang. RBAC menjadi prasyarat kredibilitas audit trail – sebuah log yang mencatat aktivitas “Admin Sistem” jauh kurang bermakna dibandingkan log yang mencatat “Budi Santoso (Kabag TU, NIP 198503152010011001) mengunduh Kontrak Pembangkit X”.

Gambar 1.1 mengilustrasikan model RBAC standar NIST yang menjadi acuan utama dalam perancangan kontrol akses berbasis peran. Model ini menunjukkan bahwa hak akses tidak diberikan langsung kepada individu (users), melainkan ditetapkan pada peran (roles) yang kemudian di-assign kepada pengguna. Pendekatan ini memungkinkan pemisahan yang jelas antara identitas pengguna dan hak aksesnya, sehingga mempermudah manajemen siklus hidup akses – mulai dari provisioning saat penugasan baru hingga de-provisioning saat mutasi atau pensiun.



Gambar 1.1: Model RBAC NIST – Komponen Utama: Users, Roles, Permissions, Sessions
 Sumber: Wikimedia Commons – Role-based access control (https://commons.wikimedia.org/wiki/File:Role-based_access_control.svg)

1.1 Integrasi Konseptual dengan Sistem Kepegawaian

Hak akses tidak diberikan kepada individu, melainkan kepada peran (role) yang terikat pada:

- Jabatan/Fungsi: Otomatis *provisioning* saat mutasi/promosi, *de-provisioning* saat pensiun/resign.
- Single Sign-On (SSO): Autentikasi terpusat mengurangi risiko berbagi kata sandi dan celah akses manual.
- *Lifecycle Management*: Review hak akses berkala (minimal tahunan) untuk memastikan relevansi dengan tugas aktual.

1.2 Matriks Role × Klasifikasi Arsip PLN

Skema akses ditentukan oleh perpotongan peran organisasi dan tingkat sensitivitas arsip. Tabel 1.1 menggunakan role/jabatan aktual di lingkungan PLN yang dikelompokkan berdasarkan fungsi organisasi:

Keterangan hak akses: C = Create, R = Read, U = Update, A = Approve, E = Export/Review

[†]Dengan persetujuan atasan langsung (prosedur darurat). [‡]Kasi Tata Laksana Surat & Kearsipan.

Role berdasarkan Peraturan Direksi PT PLN (Persero) Nomor 0037.P/DIR/2022 tentang Organisasi dan Tata Kerja¹ PT PLN (Persero).

1.3 Langkah-Langkah Perancangan Skema RBAC

Bagi Manajemen Atas, perancangan skema RBAC bukan berarti merancang konfigurasi teknis sistem, melainkan memastikan bahwa proses tata kelola berikut dijalankan dengan benar oleh tim terkait:

1. Inventarisasi Peran Organisasi. Tim HR/Kepegawaian menyusun daftar seluruh peran yang bersentuhan dengan arsip digital di unit kerja. Manajemen Atas memvalidasi kelengkapan daftar ini – memastikan tidak ada peran yang terlewat.

¹PT PLN (Persero), Perdir 0037.P/DIR/2022, Organisasi dan Tata Kerja (Jakarta: PLN, 2022).

Tabel 1.1: Matriks RBAC untuk Arsip Digital PLN – Role per Fungsi Organisasi

Peran (Role) di PLN	Publik/ Internal	Terbatas	Rahasia	Vital
Operasional – Unit Kearsipan & Tata Usaha				
Staf Kearsipan/ Arsiparis	C, R	R	R [†]	–
Staf Administrasi/ TU	C, R	R	–	–
Kabag TU/ Kasubag Kearsipan	C, R, U	C, R, U	R, E	R
Kasi TLSK [‡]	C, R	R, E	R [†]	–
Fungsional – HR, Hukum, IT				
Staf HR/ Administrasi HR	C, R	R	R [†]	–
Staf Hukum/ Legal	C, R	C, R, U	R, E	R
Staf IT/ Developer, DBA	–	R	R	R [†]
Manajemen – Pusat & Unit Induk				
GM / SRM Unit Induk	R	R, U	R, U, A	R, U, A
EVP/ SVP/ VP Pusat	R	R, U	R, U, A	R, U, A
Pengawasan – SPI, GCG, Cyber Security				
Auditor SPI/ Staf Auditor	R	R, E	R, E	R, E
VP Cyber Security/ IT Sec	R	R, E	R, E	R, E
VP Compliance/ GCG	R	R, E	R, E	R, E
Sistem – Otomasi & Integrasi				
Service Account (Sistem)	Auto-capture	Auto-classify	–	–

2. Pemetaan Aset Arsip. Unit Kearsipan mengklasifikasikan seluruh arsip digital ke dalam 4 tingkat sensitivitas (Publik, Terbatas, Rahasia, Vital). Manajemen Atas menetapkan klasifikasi untuk arsip-arsip strategis yang memerlukan keputusan tingkat atas.
3. Penetapan Hak Akses Minimum. Tim IT Governance bersama Unit Kearsipan menentukan hak akses per peran per klasifikasi, berdasarkan prinsip *least privilege*. Manajemen Atas menyetujui matriks akhir dan memastikan tidak ada konflik kepentingan.
4. Validasi Segregation of Duties. Manajemen Atas memastikan tidak ada satu peran yang memiliki kombinasi hak akses yang berlebihan – misalnya, satu orang tidak boleh sekaligus membuat, menyetujui, dan mengeksport arsip vital tanpa mekanisme keseimbangan pengawasan.
5. Penulisan Prosedur *Provisioning/De-provisioning*. Tim HR dan IT menuliskan prosedur – baik otomatis (via SAP-HR/SSO) maupun manual – untuk pemberian dan pencabutan hak akses. Manajemen Atas menyetujui prosedur ini dan memastikan ada mekanisme penanganan kasus darurat (misal: pencabutan akses segera saat terjadi insiden).
6. Penetapan Jadwal Review Berkala. Manajemen Atas menetapkan frekuensi review hak akses (minimal tahunan) dan menunjuk penanggung jawab pelaksanaannya. Review harus menghasilkan daftar hak akses yang dicabut atau dimodifikasi.

Pertanyaan kunci untuk Manajemen Atas: “Apakah setiap peran di unit ini hanya memiliki hak akses yang benar-benar diperlukan untuk menjalankan tugasnya? Dan apakah hak akses langsung dicabut saat seseorang pindah tugas, mutasi, atau pensiun – tanpa harus menunggu ada keluhan?”

Ringkasan untuk Manajemen Atas – Bab 1

RBAC adalah fondasi keterlacakan: tanpa kontrol akses yang jelas, audit trail menjadi tidak bermakna karena tidak dapat dipastikan bahwa setiap aksi tercatat atas nama pihak yang berwenang. Tiga pesan kunci yang harus dibawa Manajemen Atas dari bab ini: (1) RBAC bukan konfigurasi IT, melainkan keputusan tata kelola tentang siapa boleh mengakses apa; (2) matriks peran harus mencakup pemisahan fungsi (*segregation of duties*) agar tidak ada satu orang yang terlalu kuat; dan (3) proses provisioning/de-provisioning harus terhubung dengan siklus hidup kepegawaian melalui SAP-HR/SSO.

1.4 Aktivitas Workshop (30 Menit)

1. Identifikasi 3 peran kunci di unit Anda yang bersentuhan dengan arsip.
2. Tentukan hak akses (CRU) untuk 3 klasifikasi arsip operasional.
3. Rancang mekanisme review dan revokasi akses tahunan.

Output Portofolio

Portofolio 1 (Pilar 1: Kontrol Akses): Matriks RBAC Terintegrasi + Prosedur *Provisioning/De-provisioning*. Dinilai berdasarkan kemampuan peserta merancang skema kontrol akses berbasis peran yang menghubungkan sistem kearsipan dengan sistem kepegawaian, kejelasan role, prinsip *least privilege*, dan keterkaitan dengan siklus hidup kepegawaian.

Bab 2

Mekanisme Audit Trail Otomatis & Keterlacakan

(Kriteria Penilaian 4.4.2 – Target Kompetensi 2)

Mengapa bab ini berurutan setelah RBAC? Skema RBAC yang dirancang pada Bab 1 (Pilar 1) menentukan siapa yang berhak mengakses arsip. Namun, hak akses tanpa pencatatan yang akurat ibarat pintu tanpa kamera CCTV – kita tidak pernah tahu siapa yang masuk, kapan, dan melakukan apa. Audit trail (Pilar 2) menjembatani celah tersebut dengan mencatat setiap aktivitas akses, sehingga mewujudkan keterlacakan (traceability) yang menjadi inti dari akuntabilitas korporasi. Dengan kata lain: RBAC mengontrol akses, audit trail membuktikan kepatuhan.

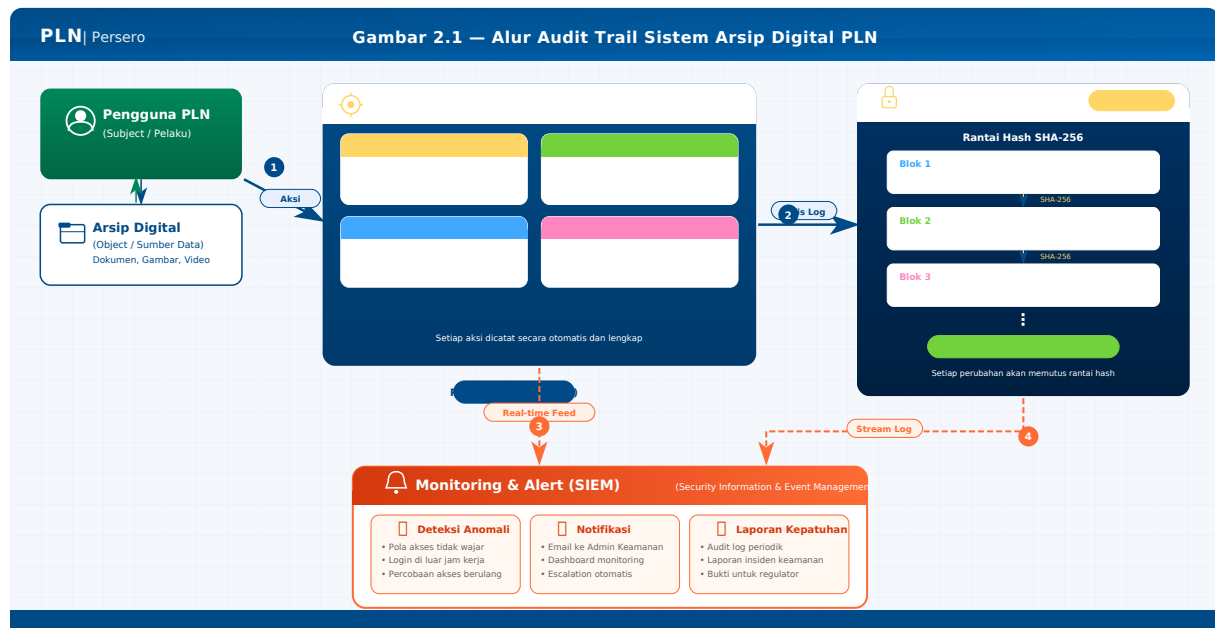
Bab ini mendukung pencapaian Pilar 2: Audit Trail – peserta mampu merancang mekanisme audit trail otomatis yang merekam setiap akses dan perubahan arsip. Audit trail adalah jejak digital immutable yang merekam setiap interaksi dengan arsip – mulai dari akses baca, pengubahan konten, persetujuan, hingga ekspor. Tanpa audit trail yang terdesain sejak awal, arsip digital kehilangan kekuatan hukum dan akuntabilitasnya.

Dua konsep teknis kunci yang menjadi fondasi mekanisme audit trail perlu dipahami oleh Manajemen Atas dalam konteks bisnis, bukan teknis:

SIEM (Security Information and Event Management) adalah sistem yang secara terpusat mengumpulkan, menganalisis, dan mengkorelasikan data log dari berbagai sumber (sistem kearsipan, jaringan, perangkat akses) untuk mendeteksi pola aktivitas yang mencurigakan atau melanggar kebijakan. Bagi Manajemen Atas, SIEM berfungsi sebagai “kamera pengawas digital” yang mengubah ribuan baris log mentah menjadi informasi yang dapat ditindaklanjuti – misalnya, memberikan notifikasi otomatis ketika arsip Rahasia diunduh di luar jam kerja oleh peran yang tidak biasanya mengaksesnya. Tanpa SIEM, log audit tetap tercatat tetapi tidak ada yang memantaunya secara proaktif.

Hash Chain adalah mekanisme yang menghubungkan setiap entri log audit secara kriptografis, sedemikian sehingga setiap entri berisi jejak (hash) dari entri sebelumnya. Praktisnya, jika satu byte data dalam log diubah secara tidak sah, hash entri tersebut akan berubah dan menyebabkan seluruh rantai hash berikutnya gagal verifikasi – sehingga manipulasi langsung terdeteksi. Bagi Manajemen Atas, hash chain menjamin bahwa log audit tidak dapat dimanipulasi oleh pihak mana pun – termasuk administrator sistem – sehingga catatan audit tetap kredibel sebagai bukti hukum di mata regulator.

Gambar 2.1 memperlihatkan alur audit trail secara menyeluruh dalam konteks kearsipan digital PLN. Pada sisi kiri, Pengguna PLN (staf kearsipan, manajemen, auditor, staf IT) mengakses Arsip Digital melalui sistem kearsipan. Setiap interaksi – baik berupa pembacaan, pengubahan, persetujuan, maupun ekspor – secara otomatis ditangkap oleh Audit Trail Engine yang merekam 4W metadata wajib: WHO (ID Pegawai + Role melalui SSO/IAM – sistem manajemen identitas dan akses terpusat), WHAT (jenis aksi: akses, ubah, hapus, ekspor), WHEN (timestamp ISO 8601 presisi tinggi), dan WHERE (IP Address + Lokasi/Unit PLN). Hasil pencatatan disimpan dalam Penyimpanan Log Abadi dengan kebijakan Write-Once-Read-Many (WORM) yang dihubungkan melalui hash chain SHA-256 untuk menjamin immutability. Seluruh log secara waktu nyata dipantau oleh SIEM yang melakukan deteksi anomali, notifikasi otomatis, dan pelaporan kepatuhan kepada Manajemen Atas.



Gambar 2.1: Diagram Alur Audit Trail Sistem Arsip Digital PLN – Dari Akses Pengguna hingga Penyimpanan Log Immutable
Sumber: PT PLN (Persero).

2.1 Kerangka 4W & Field Metadata Wajib

Setiap log audit wajib mencatat: WHO (ID+Role), WHAT (aksi/view/edit/approve), WHEN (timestamp ISO 8601 presisi tinggi), WHERE (sumber/IP/lokasi sistem).

Untuk memenuhi standar PP 71/2019¹ & Perka ANRI 6/2021², terapkan 14 Field Metadata Audit:

2.2 Kategori Event Audit Level Bisnis

Bagi Manajemen Atas, memahami apa yang harus dicatat lebih penting daripada memahami bagaimana sistem mencatatnya secara teknis. Manajemen Atas harus memastikan setiap kategori event berikut tercakup dalam mekanisme audit trail:

2.3 Langkah-Langkah Perancangan Mekanisme Audit Trail

Perancangan audit trail tingkat tata kelola bagi Manajemen Atas berfokus pada apa yang harus dicatat, bagaimana memantau kepatuhannya, dan bagaimana menindaklanjuti anomali – bukan pada detail implementasi teknis.

1. Tentukan Cakupan dan Retensi. Manajemen Atas menetapkan arsip apa saja yang wajib memiliki audit trail – minimal arsip Rahasia dan Vital. Tentukan juga berapa lama log harus disimpan: minimal sesuai masa retensi arsip terkait. Misalnya, jika arsip vital disimpan 25 tahun, log auditnya juga harus disimpan selama itu.

¹PP 71/2019, Penyelenggaraan Sistem dan Transaksi Elektronik, LNRI 196 (2019).

²Perka ANRI 6/2021, Pengelolaan Arsip Elektronik, BNRI 541 (2021).

Tabel 2.1: 14 Field Metadata Audit Trail (12 Wajib + 2 Semi-Mandatory)

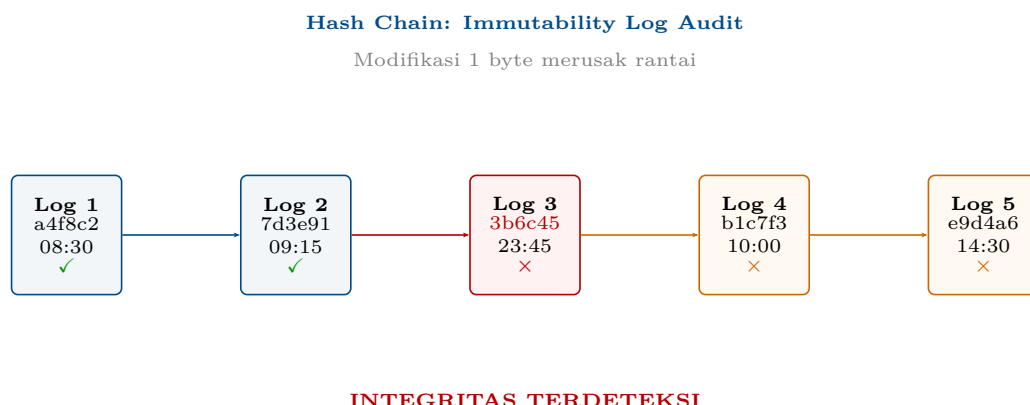
Kode	Nama Field	Sumber Data	Status
DOC_ID	ID Dokumen Unik	Sistem Nomor	Wajib
TIMESTAMP	Waktu Aksi (ISO 8601)	System Clock	Wajib
HASH_SHA256	Nilai Hash Integritas	Cryptographic Module	Wajib
CREATOR_ROLE	Peran Pengguna	IAM/SSO	Wajib
AUDIT_LOG_ID	ID Log Immutable	SIEM/Audit Engine	Wajib
CLASSIFICATION	Tingkat Keamanan	Policy Engine	Wajib
RETENTION_RULE	Aturan Retensi	Schedule DB	Wajib
ASSET_ID	Referensi Aset PLN	SAP-PM/AMS	Wajib
CONTRACT_REF	Referensi Kontrak	E-Proc/Legal	Wajib
LOCATION_GIS	Lokasi Operasional	Master Data	Wajib
INTEGRITY_HASH	Verifikasi Perubahan	Hash Module	Wajib
AUDIT_TRAIL_REF	Log Terkait	Chain Log	Wajib
CONTENT_DESC	Ringkasan Isi	NLP/Input	Semi
SEARCH_TAGS	Kata Kunci Terkontrol	Thesaurus	Semi

Tabel 2.2: Kategori Event Audit Trail untuk Arsip Digital

Kategori	Jenis Event	Relevansi Bisnis
Akses	Login, logout, view, search	Memantau siapa yang mengakses arsip sensitif dan kapan
Perubahan	Create, update, rename, reclassify	Melacak setiap modifikasi konten dan metadata arsip
Persetujuan	Approve, reject, revoke	Menjamin akuntabilitas keputusan kritis atas arsip
Ekspor	Download, print, share, export	Mengendalikan dan memantau risiko kebocoran data
Sistem	Backup, restore, delete, archive	Mencatat operasi yang memengaruhi integritas dan ketersediaan

- Validasi Kelengkapan Metadata. Pastikan tim IT mengimplementasikan 14 field metadata (Tabel 2) untuk setiap event. Manajemen Atas tidak perlu memahami implementasi teknisnya, tetapi harus meminta bukti bahwa seluruh field tercatat – misalnya melalui contoh laporan log yang dihasilkan sistem.
- Tetapkan Mekanisme Pemantauan. Manajemen Atas menunjuk tim yang bertanggung jawab memantau laporan audit trail secara berkala (misal: mingguan untuk arsip vital, bulanan untuk arsip rahasia) dan menetapkan format laporan yang diterima.
- Tetapkan Mekanisme Eskalasi. Jika terdeteksi anomali – misalnya arsip Rahasia diunduh di luar jam kerja oleh peran yang tidak biasanya mengakses – siapa yang dihubungi dalam 1 jam, 4 jam, 24 jam? Manajemen Atas menyetujui prosedur eskalasi ini.
- Pastikan Kepatuhan Regulasi. Audit trail harus memenuhi PP 71/2019 dan Perka ANRI 6/2021. Manajemen Atas meminta tim untuk memverifikasi kepatuhan dan menunjukkan bukti saat audit eksternal.

Pertanyaan kunci untuk Manajemen Atas: “Jika hari ini terjadi kebocoran arsip vital, apakah kita bisa menunjukkan siapa yang mengakses, mengubah, atau mengeksport arsip tersebut dalam 6 bulan terakhir – lengkap dengan waktu, peran, dan alasan aksesnya?”



Gambar 2.2: Konsep Hash Chain untuk Immutability Audit Log

Sumber: PT PLN (Persero).

Gambar 2.2 mengilustrasikan bagaimana setiap entri log audit dihubungkan melalui hash chain untuk menjamin immutability. Setiap blok log (Log #1 hingga Log #5) berisi hash SHA-256 dari entri saat ini, referensi hash dari entri sebelumnya, serta metadata 3W (SIAPA: ID Pegawai + Role, APA: jenis aksi, KAPAN: timestamp). Perhatikan bahwa pada contoh ini, Log #3 menunjukkan skenario pengubahan tidak sah: hash asli dicoret dan diganti, sehingga menyebabkan efek berantai – Log #4 dan Log #5 berikutnya menampilkan status verifikasi gagal karena hash referensi mereka tidak lagi cocok. Sistem SIEM secara otomatis memicu peringatan PELANGGARAN INTEGRITAS TERDETEKSI sehingga Manajemen Atas dapat segera menindaklanjuti. Prinsip kuncinya: jika 1 byte data diubah, hash blok tersebut berubah, dan seluruh hash berikutnya gagal verifikasi sehingga manipulasi langsung terdeteksi.

- Log audit disimpan terpisah dari sistem produksi dengan kebijakan Write-Once-Read-Many (WORM).
- Hash SHA-256 menjamin deteksi perubahan 1 byte seketika.
- Setiap approval wajib menggunakan Tanda Tangan Elektronik Tersertifikasi (TTE) untuk kekuatan hukum *non-repudiation*.

Ringkasan untuk Manajemen Atas – Bab 2

Audit trail mewujudkan keterlacakan (traceability) – yaitu kemampuan untuk merekonstruksi secara lengkap siapa yang mengakses, mengubah, atau mengeksport arsip tertentu pada waktu tertentu. Tiga pesan kunci dari bab ini: (1) audit trail bukan log teknis semata, melainkan bukti hukum yang sah di mata regulator (PP 71/2019, Perka ANRI 6/2021); (2) kekekalan log (immutability) melalui hash chain menjamin bahwa tidak ada pihak – termasuk admin sistem – yang dapat memanipulasi catatan tanpa terdeteksi; dan (3) deteksi anomali secara waktu nyata oleh SIEM lebih bernilai daripada investigasi pascakejadian setelah kerusakan sudah terjadi.

2.4 Aktivitas Workshop (30 Menit)

1. Gambar alur audit trail dari penciptaan → validasi → penyimpanan.
2. Lengkapi template 14 field untuk 1 jenis arsip kritis unit Anda.
3. Tentukan mekanisme eskalasi jika hash integrity gagal verifikasi.

Output Portofolio

Portofolio 2 (Pilar 2: Audit Trail): Diagram Alur Audit Trail + Template Log 14 Field. Dinilai berdasarkan kemampuan peserta merancang mekanisme audit trail otomatis yang merekam setiap akses dan perubahan arsip, kelengkapan 4W, kejelasan immutability, dan kesesuaian dengan regulasi PP 71/2019.

Bab 3

Kebijakan Keamanan Terintegrasi dengan ISMS

(Kriteria Penilaian 4.4.3 – Target Kompetensi 3)

Mengapa bab ini berurutan setelah Audit Trail? RBAC (Pilar 1) mengontrol akses dan Audit Trail (Pilar 2) mencatat akses. Namun, kedua mekanisme tersebut memerlukan payung hukum dan kerangka tata kelola agar memiliki kekuatan mengikat di level organisasi. Tanpa kebijakan keamanan yang disahkan oleh Manajemen Atas, RBAC dan audit trail hanyalah konfigurasi teknis yang tidak memiliki dasar hukum – dan dapat dengan mudah diabaikan atau diubah tanpa pertanggungjawaban. Kebijakan keamanan (Pilar 3) memberikan landasan legitimasi bagi seluruh kontrol keamanan, sekaligus memastikan keselarasan dengan standar internasional (ISO 27001), regulasi nasional (PP 71/2019), dan prinsip GCG BUMN (TARIF).

Bab ini mendukung pencapaian Pilar 3: Kebijakan Keamanan – peserta mampu merumuskan kebijakan keamanan yang terintegrasi dengan sistem manajemen keamanan informasi organisasi. Kebijakan keamanan arsip tidak boleh berdiri sendiri. Ia harus menjadi bagian tak terpisahkan dari Sistem Manajemen Keamanan Informasi (ISMS) organisasi dan mendukung prinsip GCG BUMN (TARIF).

Dua kerangka standar internasional menjadi rujukan utama dalam bab ini. Pertama, ISO/IEC 27001:2022 yang diterbitkan oleh International Organization for Standardization (ISO) merupakan kerangka manajemen keamanan informasi yang paling banyak diadopsi secara global, mencakup siklus PDCA dan 93 kontrol keamanan. Kedua, standar dan panduan yang diterbitkan oleh **NIST** (National Institute of Standards and Technology) – sebuah lembaga riset dan standar di bawah Departemen Perdagangan Amerika Serikat yang menghasilkan kerangka keamanan siber praktis seperti Cybersecurity Framework, SP 800-53 (kontrol keamanan), dan SP 800-207 (Zero Trust Architecture). Panduan NIST bersifat tidak wajib tetapi secara luas diakui sebagai referensi terbaik dalam perancangan kebijakan keamanan informasi.

3.1 Integrasi dengan ISO/IEC 27001:2022



Gambar 3.1: Siklus PDCA (Plan-Do-Check-Act) – Fondasi ISO/IEC 27001:2022

Sumber: Wikimedia Commons – PDCA Cycle (https://commons.wikimedia.org/wiki/File:PDCA_Cycle.svg)

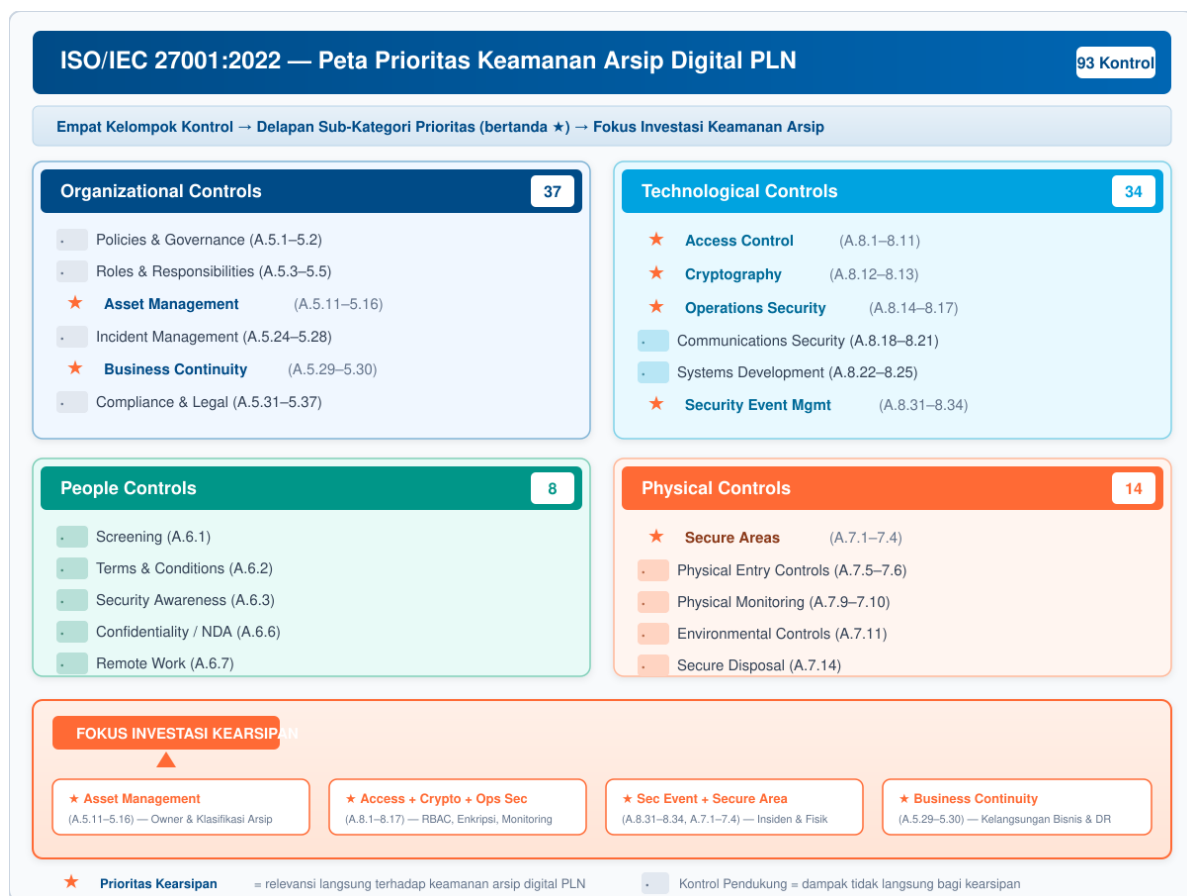
Gambar 3.1 menunjukkan siklus PDCA yang merupakan fondasi dari seluruh kerangka ISO/IEC 27001:2022. Dalam konteks keamanan arsip digital PLN, siklus ini diterjemahkan menjadi: (1) Plan – merancang kebijakan keamanan arsip, mengidentifikasi risiko, dan menetapkan kontrol; (2) Do – mengimplementasikan kontrol RBAC, backup, dan pemantauan; (3) Check – melakukan audit internal dan evaluasi kepatuhan; serta (4) Act – melakukan perbaikan berkelanjutan berdasarkan temuan audit dan insiden keamanan.

Arsip digital dikategorikan sebagai Aset Informasi Kritis. Dalam kerangka ISO/IEC 27001:2022 (edisi ke-3)¹, keamanan arsip digital menyentuh beberapa kelompok kontrol utama yang saling melengkapi. Integrasi dilakukan melalui:

- A.5.9–A.5.14 (Asset Management): Inventarisasi, klasifikasi, dan penentuan owner arsip – memastikan setiap arsip memiliki penanggung jawab yang jelas.
- A.5.1–A.5.2 (Information Security Policies): Penyelarasan kebijakan induk kearsipan dengan kebijakan keamanan informasi korporasi.
- A.8.8–A.8.17 (Operations Security): Prosedur operasional backup, monitoring log, dan penanganan insiden kebocoran.

¹ISO/IEC 27001:2022, Annex A (93 kontrol: A.5 organisasi, A.6 SDM, A.7 fisik, A.8 teknologi).

Implementasi ISO/IEC 27001:2022 di organisasi sebesar PLN tidak berarti menjalankan seluruh 93 kontrol secara bersamaan dengan prioritas yang sama. Sebagian kontrol memiliki dampak langsung terhadap keamanan arsip digital — misalnya: manajemen aset, kontrol akses, kriptografi, dan kelangsungan bisnis — sementara kontrol lain bersifat pendukung (kesadaran keamanan, keamanan fisik, pengembangan sistem). Tanpa pemetaan prioritas, Manajemen Atas berisiko mengalokasikan sumber daya pada kontrol dengan dampak rendah bagi kearsipan sementara kontrol kritis terabaikan. Gambar 3.2 berfungsi sebagai **peta jalan prioritisasi**: ia menampilkan seluruh lanskap 93 kontrol dalam 4 kelompok besar sekaligus menyorot (dengan tanda ★) sub-kategori yang memiliki relevansi tinggi terhadap keamanan arsip digital PLN. Dengan peta ini, Manajemen Atas dapat mengambil keputusan strategis berbasis bukti: fokus investasi pada kontrol bertanda bintang terlebih dahulu, baru melengkapi kontrol pendukung sesuai ketersediaan anggaran.



Gambar 3.2: Peta Area Kontrol ISO/IEC 27001:2022 – 93 Kontrol dalam 4 Kelompok dengan Indikator Relevansi Kearsipan

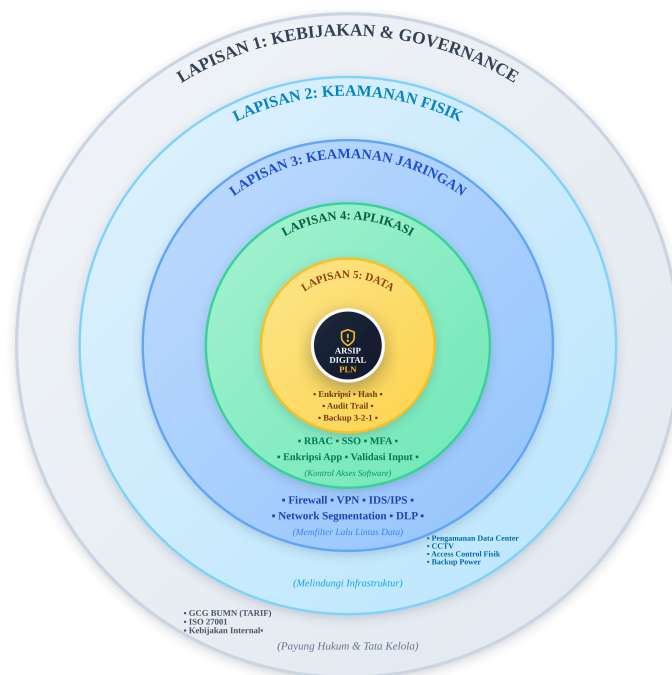
Sumber: ISO/IEC 27001:2022, diadaptasi untuk konteks PLN.

Gambar 3.2 memetakan 93 kontrol dalam ISO/IEC 27001:2022 yang diorganisasi ke dalam 4 kelompok utama: Organizational Controls (37 kontrol), People Controls (8 kontrol), Physical Controls (14 kontrol), dan Technological Controls (34 kontrol). Indikator ★ pada setiap sub-kategori menandakan relevansi **langsung** terhadap keamanan arsip digital — bukan sekadar kontrol keamanan umum. Sub-kategori yang disorot mencakup: Manajemen Aset (memastikan setiap arsip memiliki owner dan klasifikasi), Business Continuity (melindungi arsip dari bencana), Kontrol Akses (RBAC dan enkripsi), Kriptografi (enkripsi data arsip), Operasional Keamanan (monitoring dan backup), serta Manajemen Insiden (respons terhadap kebocoran data). **Rele-**

vansi strategisnya: ketika Manajemen Atas menghadapi keterbatasan anggaran atau sumber daya, peta ini memberikan justifikasi obyektif untuk memprioritaskan investasi pada sub-kategori bertanda bintang. Sebaliknya, jika sub-kategori bertanda bintang belum terimplementasi dengan baik, organisasi menghadapi risiko kepatuhan yang signifikan terhadap PP 71/2019 dan Perka ANRI 6/2021, meskipun kontrol pendukung lainnya sudah lengkap.

3.2 Tiga Prinsip Fundamental Kebijakan

Sebelum membahas detail kontrol ISO 27001:2022 pada Gambar 3.2, Manajemen Atas perlu memahami tiga prinsip fundamental yang menjadi landasan filosofis seluruh kebijakan keamanan arsip digital. Ketiga prinsip ini bukan konsep teknis, melainkan keputusan strategis yang harus diinternalisasi oleh Manajemen Atas sebagai basis pengambilan keputusan tata kelola keamanan informasi.



Gambar 3.3: Defense in Depth – 5 Lapisan Keamanan Berlapis untuk Melindungi Arsip Digital PLN

Sumber: NIST SP 800-53.

Gambar 3.3 mengilustrasikan konsep Defense in Depth dalam konteks keamanan arsip digital PLN, yang terdiri dari 5 lapisan keamanan berlapis dari luar ke dalam. Lapisan 1 – Kebijakan & Governance (terluar) membentuk payung hukum dan tata kelola: GCG BUMN (TARIF), ISO 27001, dan kebijakan keamanan arsip internal PLN. Lapisan 2 – Keamanan Fisik melindungi infrastruktur: pengamanan data center, CCTV, access control fisik, dan backup power. Lapisan 3 – Keamanan Jaringan memfilter lalu lintas data: firewall, VPN, IDS/IPS, network segmentation, dan DLP. Lapisan 4 – Keamanan Aplikasi mengontrol akses pada level perangkat lunak: RBAC, SSO, MFA, enkripsi aplikasi, dan validasi input. Lapisan 5 – Keamanan Data (terdalam) melindungi inti aset: enkripsi data, hash integrity, audit trail immutable, dan backup 3-2-1. Di inti paling dalam terdapat Arsip Digital PLN sebagai aset yang dilindungi. Prinsip utamanya: tidak ada satu lapisan pun yang cukup untuk melindungi arsip secara mandiri – jika satu lapisan berhasil ditembus, lapisan berikutnya masih memberikan proteksi.

Gambar 3.4 menampilkan General Zero Trust Architecture Reference dari NIST yang menggambarkan seluruh komponen logis arsitektur Zero Trust. Diagram ini terbagi menjadi dua bidang: *Control Plane* yang menangani keputusan kebijakan, dan *Data Plane* yang menangani transmisi data aktual. Subject (pengguna/perangkat) mengajukan permintaan akses melalui Policy Enforcement Point (PEP), yang kemudian meneruskan data verifikasi ke Policy Decision Point (PDP) – yang terdiri dari Policy Engine (PE) dan Policy Administrator (PA). PDP meminta data kontekstual dari Policy Information Points (PIPs) yang mencakup ICAM (identitas), Endpoint Security, Security Analytics, dan Data Security. Berdasarkan evaluasi ini, PDP mengembalikan keputusan *allow/deny/limit* kepada PEP, yang kemudian membolehkan atau menolak akses ke Resource. Perhatikan bahwa setiap alur diberi label (I, S, R) menunjukkan verifikasi berkelanjutan, bukan sekadar autentikasi satu kali.

1. **Least Privilege:** Hak akses minimum yang diperlukan untuk menyelesaikan tugas.
2. **Defense in Depth:** Lapisan pengamanan berlapis (fisik, jaringan, aplikasi, data, kebijakan).
3. **Zero Trust:** Tidak ada akses default. Setiap permintaan diverifikasi secara eksplisit berdasarkan konteks (role, device, lokasi, waktu).

Gambar 3.5 mengadaptasi arsitektur Zero Trust NIST (Gambar 3.4) ke dalam konteks spesifik keamanan arsip digital PLN dengan arsitektur lengkap yang terdiri dari Control Plane (keputusan kebijakan) dan Data Plane (transmisi data). Pada Control Plane, Policy Engine (PE) dan Policy Administrator (PA) bekerja sama untuk mengevaluasi dan mengelola kebijakan akses. PE menerima data verifikasi dari PEP dan melakukan query ke empat Policy Information Points (PIPs): (1) PIP: ICAM untuk data identitas dan akses (SSO, MFA, RBAC), (2) PIP: Endpoint untuk keamanan perangkat (Device Trust, MDM), (3) PIP: Analytics untuk deteksi ancaman real-time, dan (4) PIP: Data Security untuk klasifikasi dan integritas data arsip.

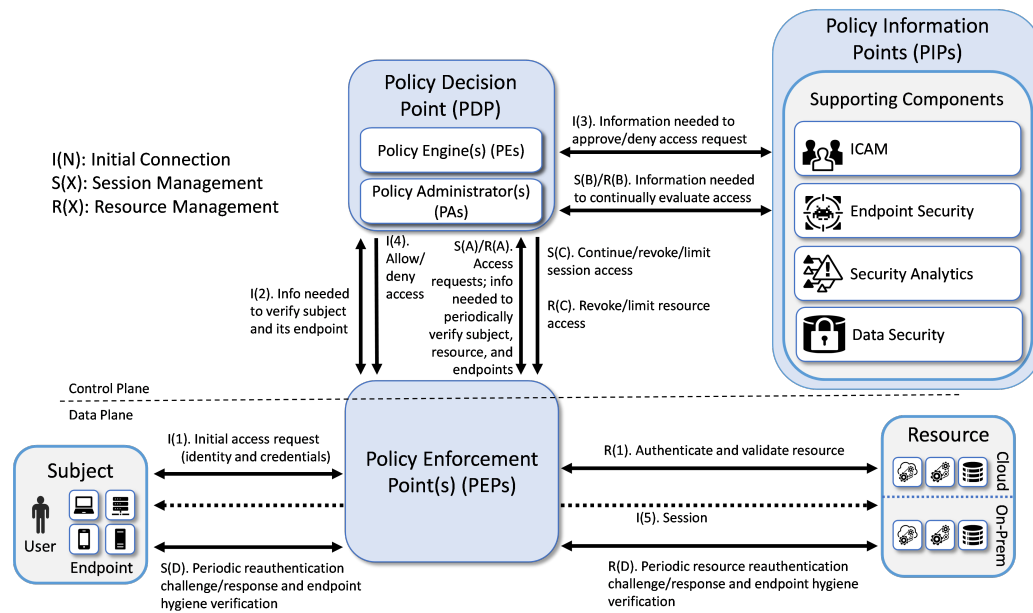
Pada Data Plane, Subject (pegawai PLN dengan berbagai role: Staf Kearsipan, GM/SVP, Auditor SPI, Staf IT) yang telah terautentikasi melalui SSO + MFA + Device Trust mengajukan permintaan akses ke Policy Enforcement Point (PEP). PEP melakukan 4 tahap verifikasi awal: (1) identitas melalui RBAC, (2) integritas perangkat, (3) konteks lokasi dan waktu, serta (4) klasifikasi arsip yang diminta. Data verifikasi ini dikirim ke Control Plane untuk evaluasi mendalam.

Berdasarkan respons dari PIPs, PE mengembalikan keputusan (Allow/Deny/Limit) ke PEP. Jika diizinkan, PEP memberikan akses ke Resource berupa arsip digital PLN yang terklasifikasi berdasarkan tingkat keamanan: Vital (merah), Rahasia (orange), Terbatas (biru), dan Publik (hijau). Setiap klasifikasi memiliki hak akses berbeda (Create/Read/Update/Archive/Erase). Jika verifikasi gagal, akses ditolak dan dieskalasi ke Manajemen Atas untuk review manual.

Seluruh aktivitas dicatat dalam Audit Trail immutable dengan hash chain SHA-256, memungkinkan verifikasi berkelanjutan (Continuous Verification) sesuai prinsip Zero Trust NIST. Trust factors yang dievaluasi mencakup: role pengguna, integritas perangkat, lokasi geografis, waktu akses, sensitivitas data, dan konteks ancaman. Pendekatan ini sangat relevan untuk PLN dengan infrastruktur tersebar di seluruh Indonesia, memastikan bahwa tidak ada akses default dan setiap permintaan diverifikasi secara eksplisit berdasarkan konteks real-time.

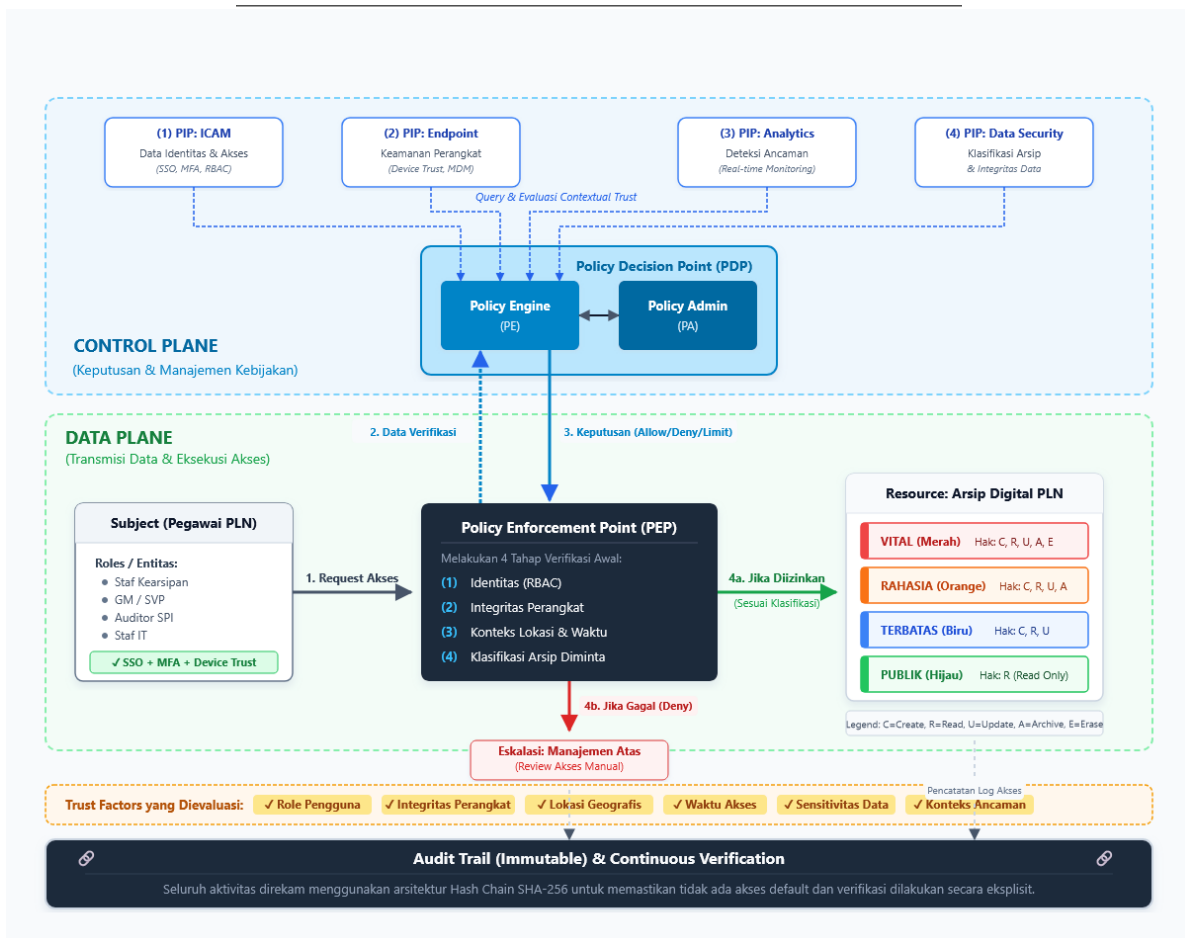
3.3 Integrasi GCG BUMN (TARIF)

TARIF adalah akronim dari lima prinsip tata kelola yang menjadi tolok ukur kinerja BUMN sebagaimana diatur dalam Permen BUMN PER-2/MBU/03/2023 tentang Pedoman GCG Signifikan BUMN. Kelima prinsip ini memiliki implikasi langsung terhadap kebijakan keamanan arsip digital. Tabel 3.1 merangkum implementasi setiap prinsip TARIF dalam konteks kebijakan keamanan arsip:



Gambar 3.4: Arsitektur Zero Trust Referensi NIST – Komponen Utama: Subject, PEP, PDP (PE + PA), PIPs, dan Resource

Sumber: NIST SP 1800-35 – Implementing a Zero Trust Architecture, Figure 1 (Public Domain) (<https://pages.nist.gov/zero-trust-architecture/>)



Gambar 3.5: Model Zero Trust untuk Keamanan Arsip Digital PLN – Arsitektur Lengkap dengan Control Plane dan Data Plane

Sumber: NIST SP 800-207 Zero Trust Architecture, diadaptasi untuk konteks PLN.

Tabel 3.1: Pemetaan Prinsip GCG ke Kebijakan Keamanan Arsip

Prinsip TARIF	Implementasi dalam Kebijakan Arsip
Transparansi	Audit trail dapat diakses Auditor Internal/Eksternal sesuai kewenangan
Akuntabilitas	RACI digital jelas; setiap aksi terikat identitas dan TTE
Responsibilitas	Kepatuhan PP 71/2019 & Perka ANRI 6/2021 wajib diuji berkala
Independensi	Unit Kearsipan berwenang tolak arsip tidak memenuhi standar metadata
Fairness	Akses berbasis need-to-know, tidak diskriminatif, ada mekanisme banding

Berikut penjelasan detail dari kelima prinsip TARIF dan implementasinya dalam kebijakan keamanan arsip digital:

- **Transparansi (Transparency)** – Kebijakan keamanan arsip harus dapat diakses dan dipahami oleh seluruh pemangku kepentingan yang berkepentingan, termasuk auditor eksternal. Hal ini tercermin dalam keterbukaan audit trail dan prosedur akses.
- **Akuntabilitas (Accountability)** – Setiap aksi terhadap arsip harus dapat dipertanggungjawabkan kepada individu dan peran yang spesifik. Hal ini diterjemahkan melalui matriks RACI digital dan penggunaan Tanda Tangan Elektronik Tersertifikasi (TTE).
- **Responsibilitas (Responsibility)** – Organisasi memiliki kewajiban untuk mematuhi regulasi kearsipan nasional (PP 71/2019, Perka ANRI 6/2021) dan membuktikan kepatuhan tersebut secara berkala melalui audit internal dan eksternal.
- **Independensi (Independence)** – Unit Kearsipan dan fungsi pengawasan harus memiliki kewenangan untuk menolak arsip yang tidak memenuhi standar metadata, tanpa tekanan dari pihak manapun. Hal ini menjamin integritas sistem kearsipan secara keseluruhan.
- **Kewajaran (Fairness)** – Kebijakan akses harus berbasis prinsip need-to-know dan tidak diskriminatif, dengan mekanisme banding bagi pengguna yang merasa hak aksesnya tidak sesuai.

3.4 Langkah-Langkah Perumusan Kebijakan Keamanan

Merumuskan kebijakan keamanan arsip bukan aktivitas satu kali, melainkan proses tata kelola yang berkelanjutan. Bagi Manajemen Atas, tahapan berikut harus dipastikan terlaksana:

1. Analisis Risiko Kearsipan. Sebelum menulis kebijakan, lakukan identifikasi risiko keamanan arsip digital di unit Anda – apa ancaman terbesar (kebocoran internal, serangan siber, bencana alam, kelalaian pegawai?), kemungkinan terjadinya, dan dampaknya terhadap bisnis. Hasil analisis risiko ini menjadi dasar prioritas kebijakan. Tanpa analisis risiko, kebijakan menjadi tidak berbasis bukti.
2. Penyusunan Draf oleh TimLintas. Tim Kearsipan bersama IT Governance dan Legal menyusun draf kebijakan. Gunakan template kerangka (Bagian 3.5) sebagai acuan minimal.
3. Konsultasi Internal. Draf dikonsultasikan dengan unit terkait (Legal, IT, HR, Unit Kearsipan). Pastikan setiap prinsip TARIF terakomodasi dan tidak ada konflik kepentingan antar-unit.
4. Penetapan dan Pengesahan. Manajemen Atas mengesahkan kebijakan, menetapkan tanggal efektif berlaku, dan menunjuk penanggung jawab implementasi.

5. Sosialisasi dan Implementasi. Pastikan seluruh pihak terkait memahami kebijakan baru. Tetapkan timeline implementasi bertahap dan kriteria keberhasilan.
6. Review dan Pembaruan Berkala. Sesuai siklus PDCA (Gambar 3.1), kebijakan harus ditinjau minimal tahunan atau segera setelah terjadi insiden keamanan arsip yang signifikan.

3.5 Template Kerangka Kebijakan Keamanan Arsip Digital

Berikut adalah kerangka kebijakan yang dapat digunakan oleh Manajemen Atas sebagai acuan minimal untuk menilai kecukupan draf dari tim. Setiap klausul harus dikembangkan sesuai konteks dan kebutuhan spesifik unit masing-masing.

Klausul 1: Ruang Lingkup dan Tujuan

Kebijakan ini berlaku untuk seluruh arsip digital yang dikelola oleh [Nama Unit]. Tujuannya adalah menjamin keamanan, integritas, keterlacakan, dan ketersediaan arsip digital sepanjang siklus hidupnya, sesuai dengan regulasi yang berlaku.

Klausul 2: Kontrol Akses (merujuk Pilar 1)

Akses terhadap arsip digital diberikan berdasarkan peran (RBAC) sesuai matriks yang ditetapkan dalam lampiran. Prinsip *least privilege* wajib diterapkan. Pemberian hak akses baru memerlukan persetujuan [Jabatan], dan pencabutan akses dilakukan paling lambat [waktu] setelah perubahan status kepegawaian.

Klausul 3: Audit Trail dan Keterlacakan (merujuk Pilar 2)

Setiap akses, perubahan, dan persetujuan terhadap arsip [Klasifikasi: Rahasia/Vital] wajib dicatat dalam log audit yang memenuhi standar 14 field metadata (lihat lampiran). Log audit bersifat immutable dan disimpan terpisah dari sistem produksi selama minimal [periode retensi, sesuai retensi arsipnya].

Klausul 4: Backup dan Pemulihan (merujuk Pilar 4)

Arsip digital wajib dibackup sesuai strategi 3-2-1. Target RTO dan RPO ditetapkan berdasarkan klasifikasi arsip (lihat matriks RTO/RPO). Uji simulasi pemulihan dilakukan minimal setiap 6 bulan dengan dokumentasi hasil dan rekomendasi perbaikan.

Klausul 5: Peran dan Tanggung Jawab

Matriks RACI (Responsible, Accountable, Consulted, Informed) disusun sebagai lampiran dokumen kebijakan ini. Sebagai panduan minimal: Accountable untuk kebijakan keamanan arsip adalah GM/SVP level unit; Responsible adalah Kepala Unit Kearsipan bersama Kepala IT Governance; Consulted meliputi Legal, HR, dan SPI; serta Informed mencakup seluruh pegawai yang mengakses arsip digital. Kebijakan ini merupakan bagian dari ISMS organisasi yang berlaku.

Klausul 6: Kepatuhan dan Peninjauan

Kepatuhan terhadap kebijakan ini dievaluasi melalui audit internal minimal [frekuensi]. Kebijakan ditinjau oleh [Jabatan] minimal setiap [periode] atau segera setelah insiden keamanan arsip yang signifikan.

Ringkasan untuk Manajemen Atas – Bab 3

Kebijakan keamanan arsip adalah payung hukum yang memberikan legitimasi dan keberlanjutan bagi seluruh mekanisme keamanan (RBAC, audit trail, backup). Tiga pesan kunci: (1) kebijakan harus terintegrasi dengan ISMS organisasi (ISO 27001:2022), bukan dokumen yang berdiri sendiri; (2) tiga prinsip fundamental – Least Privilege, Defense in Depth, dan Zero Trust – harus tercermin dalam setiap klausul kebijakan; dan (3) kebijakan yang tidak ditinjau secara berkala (minimal tahunan) akan menjadi usang dan kehilangan kekuatan hukumnya. Manajemen Atas adalah penandatanganan dan penanggung jawab utama kebijakan ini.

3.6 Aktivitas Workshop (30 Menit)

1. Susun draf klausul kebijakan keamanan arsip (maks. 2 halaman).
2. Petakan minimal 3 kontrol ISO 27001 yang relevan dengan unit Anda.
3. Integrasikan 1 klausul pendukung prinsip TARIF.

Output Portofolio

Portofolio 3 (Pilar 3: Kebijakan Keamanan): Rancangan Kebijakan Keamanan Arsip Terintegrasi ISMS. Dinilai berdasarkan kemampuan peserta merumuskan kebijakan keamanan yang terintegrasi dengan ISMS organisasi, keselarasan ISO 27001, kejelasan prinsip Zero Trust/Least Privilege, dan integrasi GCG BUMN.

Bab 4

Sistem Backup & Disaster Recovery Terintegrasi

(Kriteria Penilaian 4.4.4 – Target Kompetensi 4)

Bab ini mendukung pencapaian Pilar 4: Pemulihan Data – peserta mampu merancang sistem backup dan disaster recovery terintegrasi. Keamanan arsip tidak lengkap tanpa jaminan ketersediaan pasca-gangguan. Fokus pada level kebijakan: strategi, target pemulihan, dan kesiapan organisasi.

Mengapa bab ini berurutan setelah Kebijakan Keamanan? Kebijakan keamanan (Pilar 3) menetapkan apa yang harus dilindungi dan bagaimana standar perlindungannya. Namun, kebijakan tanpa mekanisme pemulihan (backup/DR) hanya mengelola risiko secara parsial – arsip yang sangat aman tetapi tidak dapat dipulihkan saat terjadi bencana sama buruknya dengan arsip yang tidak aman. ISO 27001:2022 secara eksplisit mengklasifikasikan backup sebagai kontrol wajib (A.8.13 Information Backup)¹, dan ISO 22301:2019² mewajibkan organisasi memiliki rencana kelangsungan bisnis. Backup dan Disaster Recovery (Pilar 4) melengkapi tiga pilar sebelumnya dengan menjamin bahwa arsip yang dilindungi oleh RBAC (Pilar 1), dicatat oleh audit trail (Pilar 2), dan diatur oleh kebijakan (Pilar 3) juga tersedia saat dibutuhkan – bahkan dalam kondisi terburuk sekalipun.

4.1 Strategi Backup 3-2-1 untuk Arsip PLN

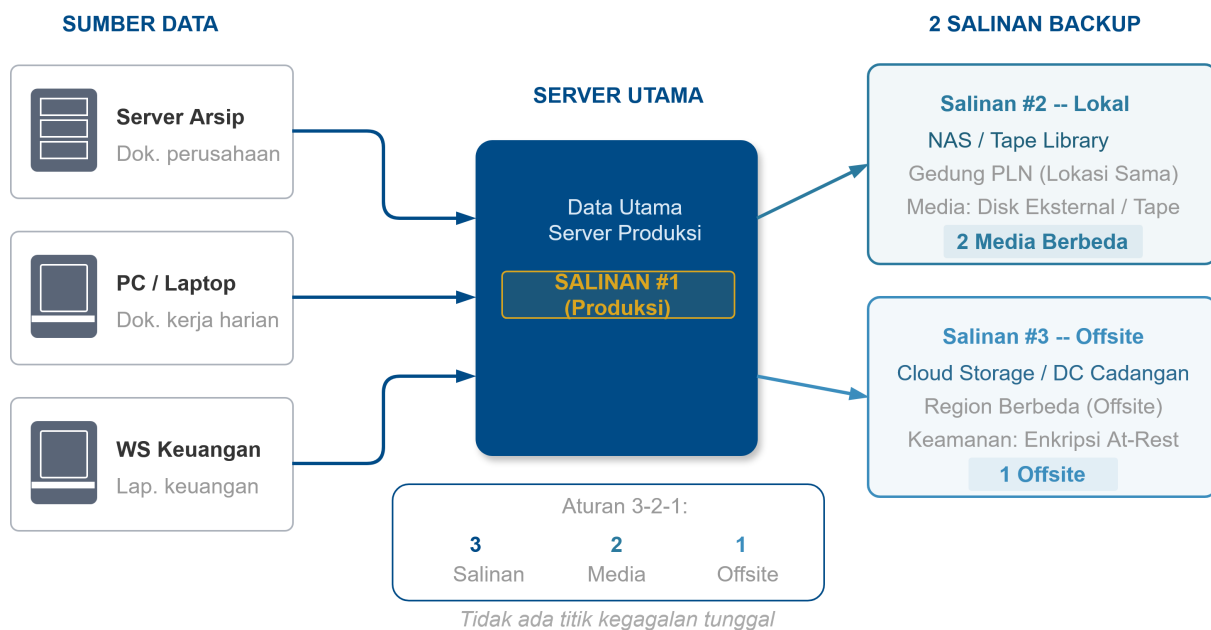
Gambar 4.1 mengilustrasikan penerapan strategi 3-2-1 backup rule yang direkomendasikan oleh US-CERT/CISA dalam konteks kearsipan digital PLN. Pada sisi kiri, terdapat tiga sumber data: Server Arsip (dokumen perusahaan), PC/Laptop Staf (dokumen kerja harian), dan Workstation Keuangan (laporan keuangan) yang seluruhnya terhubung ke Data Utama (server produksi) di tengah. Dari server utama, data direplikasi ke dua lokasi backup: (1) Salinan #2 – Lokal yang disimpan pada NAS/Tape Library dalam gedung PLN yang sama menggunakan media disk eksternal atau tape; dan (2) Salinan #3 – Offsite yang disimpan pada Cloud Storage atau Data Center cadangan di region berbeda. Prinsip 3-2-1 menjamin bahwa kehilangan data akibat kegagalan perangkat, bencana lokasi, atau serangan siber dapat diminimalkan secara signifikan, karena tidak ada satu pun titik kegagalan tunggal yang dapat mengkompromikan seluruh salinan data secara bersamaan.

- 3 salinan data (produksi + 2 backup)
- 2 media penyimpanan berbeda (misal: NAS lokal + Cloud/Offsite terenkripsi)
- 1 salinan disimpan di lokasi geografis terpisah dari data center utama

Kebijakan wajib mencantumkan jadwal backup otomatis, enkripsi *at-rest/in-transit*, dan verifikasi integritas pasca-backup.

¹ISO/IEC 27001:2022, cl. A.8.13.

²ISO 22301:2019, *Business Continuity Management Systems – Requirements*, 2nd ed. (Geneva: ISO, 2019).



Gambar 4.1: Strategi Backup 3-2-1 untuk Arsip Digital PLN – 3 Salinan, 2 Media, 1 Offsite

Sumber: US-CERT/CISA.

4.2 Penetapan RTO & RPO Berbasis Criticality

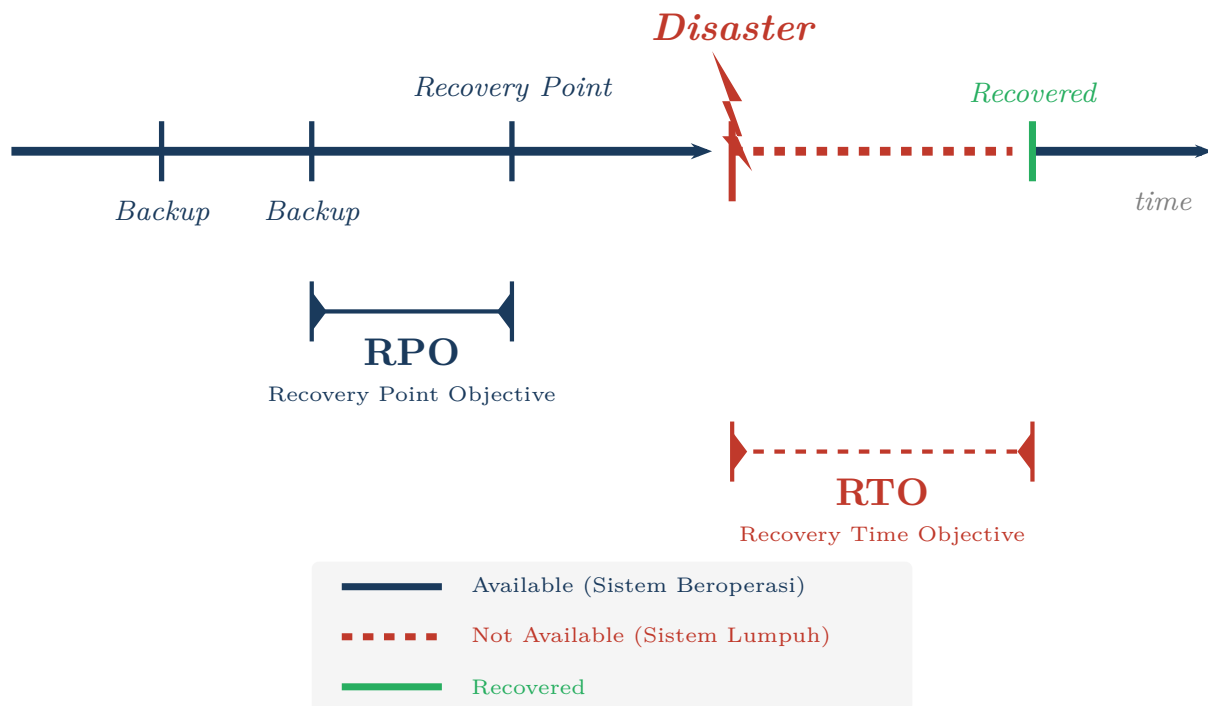
Strategi backup 3-2-1 pada Bagian 4.1 menjawab pertanyaan “bagaimana” data arsip dilindungi – yaitu melalui replikasi ke berbagai media dan lokasi. Namun, strategi backup saja tidak cukup; Manajemen Atas juga harus menetapkan “seberapa cepat” sistem harus pulih dan “seberapa banyak data yang boleh hilang” ketika gangguan terjadi. Dua pertanyaan inilah yang dijawab oleh Recovery Time Objective (RTO) dan Recovery Point Objective (RPO).

Penetapan RTO dan RPO bukanlah keputusan teknis semata, melainkan keputusan strategis yang harus diambil oleh Manajemen Atas berdasarkan dua pertimbangan utama. Pertama, pertimbangan tingkat kepentingan arsip: dokumen seperti kontrak pembangkit listrik atau laporan keuangan teraudit memiliki dampak yang jauh lebih besar jika hilang dibandingkan dengan surat edaran internal, sehingga membutuhkan target pemulihan yang lebih ketat. Kedua, pertimbangan keseimbangan biaya dan risiko: menetapkan RTO dan RPO yang terlalu agresif untuk seluruh arsip akan mengakibatkan pembengkakan biaya infrastruktur tanpa proporsi manfaat yang sepadan. Sebaliknya, target yang terlalu longgar berarti PLN harus menerima risiko downtime yang lebih lama dan potensi kehilangan data yang lebih besar – sebuah risiko yang dapat berujung pada sanksi regulasi, kerugian finansial, atau gangguan pelayanan publik.

Bagian ini membahas konsep RTO dan RPO secara visual melalui diagram timeline (Gambar 4.2), kemudian menghubungkannya dengan klasifikasi keamanan arsip PLN sebagaimana diatur dalam Perdir 0037.P/DIR/2022 untuk menghasilkan target pemulihan yang proporsional dan terukur.

Gambar 4.2 mengilustrasikan hubungan antara dua metrik kritis dalam perencanaan disaster recovery melalui sebuah garis waktu (timeline) horizontal. Untuk memahami diagram ini, mari ikuti alur dari kiri ke kanan.

Tahap 1 – Sistem Beroperasi Normal. Pada awal timeline, garis kontinu menandakan bahwa sistem arsip digital beroperasi secara normal dan data tersedia (Available). Pada periode ini, terlihat dua titik Backup yang menunjukkan bahwa backup data dilakukan secara berkala



Gambar 4.2: Timeline RTO dan RPO – Hubungan antara Titik Pemulihan Data dan Waktu Pemulihan Sistem

Sumber: NIST SP 800-34 Rev. 1.

– misalnya setiap jam atau setiap hari, tergantung kebijakan unit. Semakin sering backup dilakukan, semakin kecil celah kehilangan data jika bencana terjadi.

Tahap 2 – Terjadi Bencana. Di tengah diagram, sebuah ikon menandai momen Disaster – yaitu saat sistem mengalami gangguan besar, baik akibat serangan siber, kegagalan perangkat keras, bencana alam, atau kesalahan manusia. Pada titik inilah garis timeline berubah menjadi putus-putus, menandakan transisi dari status Available (sistem berjalan) menjadi Not Available (sistem lumpuh). Selama periode ini, arsip digital tidak dapat diakses oleh pemangku kepentingan.

Tahap 3 – Sistem Dipulihkan. Setelah masa pemulihan, titik Recovered menandai momen ketika sistem berhasil dipulihkan dan arsip kembali dapat diakses. Timeline kembali kontinu, mengindikasikan operasional normal telah ter restore.

Dari alur tersebut, dua metrik kunci dapat diidentifikasi melalui bracket (kurung pengukur) di bawah timeline:

- RPO (Recovery Point Objective) – diukur oleh bracket yang membentang dari titik Backup terakhir menuju Recovery Point. RPO menjawab pertanyaan: “Seberapa banyak data yang hilang?” Jika backup terakhir dilakukan pukul 08.00 dan bencana terjadi pukul 11.30, maka $RPO = 3,5$ jam – artinya seluruh data yang dibuat/ubah antara pukul 08.00–11.30 berpotensi hilang dan harus direkonstruksi ulang. Semakin kecil RPO, semakin sedikit data yang hilang – tetapi membutuhkan frekuensi backup yang lebih tinggi dan biaya infrastruktur yang lebih besar.
- RTO (Recovery Time Objective) – diukur oleh bracket yang membentang dari titik Disaster menuju Recovered. RTO menjawab pertanyaan: “Seberapa lama sistem lumpuh total?” Jika disaster terjadi pukul 11.30 dan sistem baru pulih pukul 15.30, maka $RTO = 4$ jam. Selama 4 jam tersebut, seluruh akses terhadap arsip digital PLN tidak tersedia – karyawan tidak bisa mengunduh kontrak, auditor tidak bisa memeriksa laporan keuangan, dan manajemen

tidak bisa mengakses dokumen RUPS. Semakin kecil RTO, semakin cepat pemulihan – tetapi membutuhkan investasi pada teknologi *failover* otomatis, *mirror site*, dan tim respons yang terlatih.

Mengapa Manajemen Atas perlu memahami RTO dan RPO? Kedua metrik ini bukan sekadar parameter teknis – melainkan keputusan bisnis strategis yang memiliki implikasi langsung terhadap biaya operasional dan manajemen risiko PLN. Menetapkan RTO 1 jam dan RPO 15 menit untuk seluruh arsip akan sangat mahal dan tidak efisien, karena tidak semua arsip memiliki tingkat kepentingan yang sama. Oleh karena itu, penetapan RTO/RPO harus proporsional dengan klasifikasi keamanan arsip sebagaimana diatur dalam Perdir 0037.P/DIR/2022. Tabel 4.1 merangkum target pemulihan yang direkomendasikan berdasarkan tingkat kepentingan:

Tabel 4.1: Target Pemulihan (RTO/RPO) Berdasarkan Klasifikasi Arsip

Klasifikasi	RTO	RPO	Strategi Prioritas
Vital	< 4 jam	< 1 jam	<i>Mirror site</i> aktif, <i>failover</i> otomatis, replikasi waktu nyata
Rahasia	< 12 jam	< 4 jam	Backup harian terenkripsi, <i>restore</i> manual teruji
Internal/ Publik	< 24 jam	< 12 jam	Backup mingguan, arsip dingin (cold storage)

4.3 Business Continuity Plan (BCP) Kearsipan

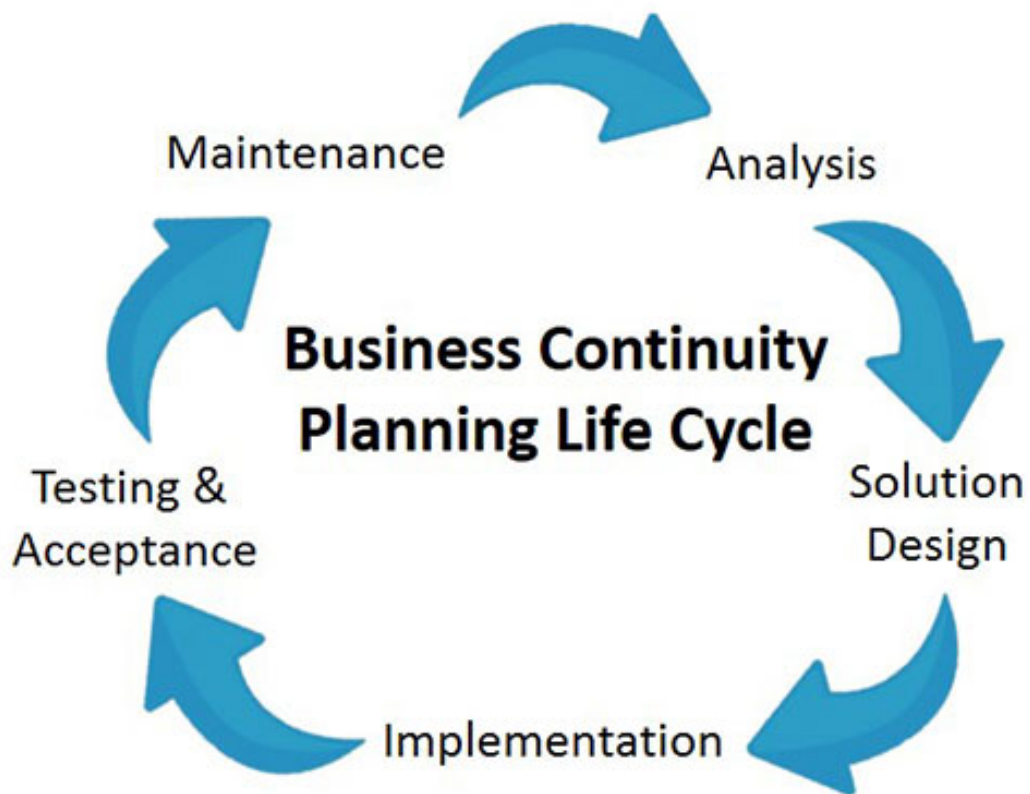
Bagian 4.2 telah membahas penetapan RTO dan RPO sebagai target pemulihan yang proporsional dengan tingkat kepentingan arsip. Namun, target pemulihan yang telah ditetapkan tidak akan berarti apa-apa tanpa sebuah rencana terstruktur yang mengatur bagaimana organisasi harus bertindak ketika gangguan benar-benar terjadi. Business Continuity Plan (BCP) adalah rencana tersebut – sebuah dokumen strategis yang memastikan PLN dapat tetap menjalankan fungsi bisnis kritis, termasuk pengelolaan arsip digital, meskipun menghadapi bencana besar.

Dalam konteks kearsipan PLN, BCP menjawab pertanyaan yang lebih luas dari sekadar teknis backup: “Jika data center utama mengalami kegagalan total, apakah kontrak pembangkit yang sedang dalam proses tender masih bisa diakses oleh panitia? Jika server arsip diretas oleh *ransomware*, apakah laporan keuangan teraudit yang dibutuhkan OJK masih tersedia untuk diaudit? Jika bencana alam melumpuhkan kantor pusat, apakah dokumen RUPS dapat direproduksi untuk pemegang saham?” Pertanyaan-pertanyaan ini bersifat manajerial, bukan teknis – dan jawabannya harus disiapkan oleh Manajemen Atas melalui penyusunan BCP yang komprehensif.

Secara internasional, kerangka BCP yang paling banyak diadopsi adalah ISO 22301:2019 (Security and resilience – Business continuity management systems). Standar ini mensyaratkan organisasi untuk menjalankan siklus manajemen kelangsungan bisnis yang mencakup analisis dampak, perancangan solusi, implementasi, pengujian, dan pemeliharaan berkelanjutan. Bagian ini membahas siklus BCP tersebut secara visual (Gambar 4.3), kemudian memfokuskan pada tahap Business Impact Analysis (BIA) yang menjadi tanggung jawab langsung Manajemen Atas dalam menentukan prioritas pemulihan arsip.

Gambar 4.3 menunjukkan siklus hidup Business Continuity Planning (BCP) yang terdiri dari 5 fase iteratif, diurutkan searah jarum jam:

1. Maintenance – pemeliharaan dan pembaruan rencana secara berkala. Fase ini memastikan bahwa BCP tetap relevan seiring berubahnya kondisi organisasi, infrastruktur, dan regulasi.



Gambar 4.3: Siklus Hidup Business Continuity Plan (BCP) – Lima Fase Iteratif ISO 22301:2019

Sumber: ISO 22301:2019.

Tanpa maintenance, rencana yang pernah sempurna akan menjadi usang dan tidak dapat diandalkan saat dibutuhkan.

2. Analysis – tahap yang menampung Business Impact Analysis (BIA) dan penilaian risiko. Fase ini ditandai dengan badge BIA pada diagram, menandakan bahwa BIA adalah aktivitas paling kritis dalam keseluruhan siklus BCP. Pada tahap ini, organisasi mengidentifikasi proses bisnis kritis, mengukur dampak ketidaktersediaan terhadap operasional dan kepatuhan regulasi, serta menetapkan RTO/RPO berdasarkan klasifikasi arsip (Vital, Rahasia, Internal/Publik).
3. Solution Design – perumusan strategi pemulihan berdasarkan temuan BIA. Output fase ini adalah strategi backup, infrastruktur *failover*, dan mekanisme pemulihan yang proporsional dengan target RTO/RPO yang telah ditetapkan pada fase Analysis.
4. Implementation – penyusunan dan pengimplementasian rencana tanggap, termasuk pembuatan prosedur operasional standar (SOP), penunjukan tim respons, dan penerapan infrastruktur backup.
5. Testing & Acceptance – pengujian, validasi, dan persetujuan rencana melalui simulasi dan uji pemulihan. Hasil pengujian menjadi umpan balik yang dialirkan kembali ke fase Maintenance untuk penyempurnaan berkelanjutan.

Panah searah jarum jam menghubungkan kelima fase secara iteratif, menandakan bahwa BCP bukan proyek satu kali selesai melainkan siklus perbaikan berkelanjutan yang sejalan dengan prinsip ISO 22301:2019. Kebijakan DR kearsipan PLN harus mencakup seluruh fase dalam siklus ini. Khusus untuk arsip vital, diperlukan prosedur *fallback* yang jelas ketika sistem elektronik mengalami *downtime* lebih dari 4 jam, termasuk mekanisme pengelolaan arsip manual sementara.

Kebijakan DR harus mencakup:

1. Prosedur *fallback* digital/manual saat sistem lumpuh > 4 jam.
2. Prioritas pemulihan: Vital → Rahasia → Internal.
3. Jadwal simulasi pemulihan minimal 6 bulan sekali dengan dokumentasi hasil evaluasi.
4. Mekanisme komunikasi krisis dan eskalasi ke manajemen puncak.

4.3.1 Analisis Dampak Bisnis (BIA) untuk Arsip Digital

BIA adalah tahap paling kritis dalam perancangan BCP/DR – dan merupakan kegiatan yang secara langsung menjadi tanggung jawab Manajemen Atas. BIA menjawab pertanyaan strategis: “Jika arsip X tidak dapat diakses selama Y jam, apa dampaknya terhadap operasional, keuangan, reputasi, dan kepatuhan regulasi?” Tanpa BIA, penetapan RTO/RPO hanyalah tebakan tanpa dasar bisnis. Tabel 4.2 menyajikan template BIA ringkas yang memetakan empat kategori klasifikasi arsip terhadap contoh arsip di PLN serta dampak operasional dan regulasinya masing-masing.

Pertanyaan kunci untuk Manajemen Atas: “Jika seluruh arsip vital unit ini musnah besok, apakah kita bisa melanjutkan operasional? Berapa kerugian finansial yang ditimbulkan? Apakah kita siap menghadapi pemeriksaan regulator?”

4.3.2 Langkah-Langkah Perancangan Sistem Backup/DR

Bagi Manajemen Atas, perancangan sistem backup dan disaster recovery berfokus pada kebijakan, target, dan kesiapan organisasi – bukan pemilihan teknologi. Tahapan tata kelola berikut harus dipastikan:

1. Lakukan BIA. Identifikasi arsip vital dan estimasi dampak ketidaktersediaan. Manajemen Atas menetapkan klasifikasi vital berdasarkan dampak bisnis.

Tabel 4.2: Template BIA Ringkas untuk Arsip Digital PLN

Kategori	Contoh Arsip di PLN	Dampak Operasional	Dampak Regulasi
Vital	Kontrak pembangkit, laporan keuangan teraudit, dokumen RUPS	Gangguan operasional nasional; potensi kerugian triliun rupiah	Pelanggaran UU Perseroan; sanksi OJK; ancaman pidana
Rahasia	Data pelanggan, dokumen tender, laporan audit	Gangguan layanan regional; potensi kebocoran data pelanggan	Pelanggaran UU PDP; ancaman pidana; denda administratif
Terbatas	SOP internal, laporan kinerja unit, surat keputusan	Gangguan operasional unit; penurunan efisiensi	Potensi temuan audit internal
Publik	Info publik, laporan tahunan, profil perusahaan	Minimal – tidak mengganggu operasional	Tidak ada

2. Tetapkan Target RTO/RPO. Berdasarkan hasil BIA, tetapkan target pemulihan yang realistis dan proporsional dengan anggaran yang tersedia. Target yang terlalu agresif tanpa anggaran yang memadai akan menjadi kebijakan di atas kertas.
3. Tetapkan Strategi Backup. Pastikan tim IT mengimplementasikan strategi 3-2-1. Manajemen Atas menyetujui alokasi anggaran untuk infrastruktur backup (cloud, offsite, enkripsi).
4. Tetapkan Prosedur *Fallback*. Jika sistem elektronik lumpuh lebih dari 4 jam, bagaimana unit beroperasi? Prosedur *fallback* manual harus ada dan pernah disimulasikan.
5. Jadwalkan dan Lakukan Simulasi. Manajemen Atas menetapkan jadwal simulasi minimal 6 bulanan dan menghadiri (atau menerima laporan) setiap simulasi. Simulasi yang tidak pernah dilakukan sama saja dengan tidak punya BCP.

Ringkasan untuk Manajemen Atas – Bab 4

Backup dan disaster recovery bukan aktivitas teknis semata – ini adalah keputusan bisnis strategis yang menentukan apakah PLN dapat terus beroperasi saat terjadi gangguan serius. Tiga pesan kunci: (1) strategi backup 3-2-1 adalah standar minimum yang harus diimplementasikan – tiga salinan, dua media berbeda, satu offsite; (2) penetapan RTO/RPO harus proporsional dengan klasifikasi arsip – tidak semua arsip memerlukan pemulihan instan, tetapi arsip vital memerlukan target yang ketat; dan (3) BCP yang tidak pernah diuji melalui simulasi sama saja dengan tidak punya BCP – Manajemen Atas harus memastikan bahwa uji pemulihan dilakukan minimal setiap 6 bulan.

4.4 Aktivitas Workshop (30 Menit)

1. Tentukan klasifikasi arsip vital di unit Anda.
2. Tetapkan target RTO/RPO realistis.
3. Rancang jadwal backup dan skenario simulasi 6 bulanan.

Output Portofolio

Portofolio 4 (Pilar 4: Pemulihan Data): Matriks RTO/RPO + Rencana Backup & DR. Dinilai berdasarkan kemampuan peserta merancang sistem backup dan disaster recovery terintegrasi, kesesuaian 3-2-1, target realistis, dan kejelasan prosedur *fallback*/simulasi.

Bab 5

Studi Kasus Terintegrasi: Insiden Kebocoran Arsip Kontrak

(Mengintegrasikan Pilar 1 hingga Pilar 4)

5.1 Skenario

Pada hari Senin pukul 08.00, Manajer Keuangan Unit Bisnis PLN XYZ menemukan bahwa dokumen kontrak jangka panjang dengan vendor strategis telah diunduh oleh 3 orang yang tidak berwenang pada hari Jumat malam pukul 23.45. Dokumen tersebut berstatus Rahasia dan mengandung informasi komersial sensitif. Insiden ini baru terdeteksi setelah 2,5 hari, ketika staf administrasi kebetulan memeriksa log sistem dan menemukan anomali.

5.2 Analisis Berbasis Empat Pilar Keamanan

5.2.1 Pilar 1: Kontrol Akses – Apakah RBAC Berfungsi?

- Temuan: Ketiga orang yang mengunduh memiliki peran Staf Administrasi. Peran ini seharusnya hanya memiliki hak Read untuk arsip Rahasia, bukan Export/Download.
- Akar Masalah: Matriks RBAC tidak membedakan antara View (membaca di layar) dan Export/Download (menyalin ke perangkat lokal). Hak Export diberikan terlalu luas kepada peran yang tidak membutuhkannya.
- Tindakan Perbaikan: Revisi matriks RBAC: pisahkan hak Read dan Export. Hak Export untuk arsip Rahasia hanya diberikan melalui prosedur darurat dengan persetujuan atasan langsung.

5.2.2 Pilar 2: Audit Trail – Apakah Audit Trail Berfungsi?

- Temuan positif: Aksi download tercatat dalam log audit dengan metadata lengkap: siapa, kapan, dari perangkat mana, berapa file yang diunduh. Tanpa audit trail, insiden ini tidak akan pernah terdeteksi.
- Temuan negatif: Insiden baru ditemukan 2,5 hari kemudian – bukan secara waktu nyata. Tidak ada mekanisme peringatan otomatis ketika arsip Rahasia diunduh di luar jam kerja (pukul 23.45), padahal ini adalah pola yang mencurigakan.
- Tindakan Perbaikan: Tetapkan aturan alert otomatis untuk event ekspor arsip Rahasia dan Vital di luar jam kerja. Manajemen Atas harus menerima notifikasi untuk event kritis.

5.2.3 Pilar 3: Kebijakan Keamanan – Apakah Kebijakan Keamanan Memadai?

- Temuan: Kebijakan keamanan arsip yang berlaku tidak mengatur secara spesifik tentang ekspor terkontrol untuk arsip Rahasia. Kebijakan hanya menyebut “akses dibatasi berdasarkan peran” tanpa membedakan akses baca dan akses salin.

- Temuan tambahan: Kebijakan belum dilakukan peninjauan selama 18 bulan, melampaui periode review tahunan yang direkomendasikan oleh standar ISO 27001.
- Tindakan Perbaikan: Revisi kebijakan untuk mencakup klausul ekspor terkontrol, tetapkan jadwal review berkala yang dipatuhi, dan pastikan proses review melibatkan seluruh pemangku kepentingan.

5.2.4 Pilar 4: Pemulihan Data – Apakah Backup/DR Berfungsi?

- Temuan positif: Arsip kontrak yang dibocorkan masih tersedia di sistem – integritas data tidak terganggu, sehingga dampak insiden bisa dibatasi pada aspek keamanan, bukan ketersediaan.
- Pertanyaan kritis: Jika insiden ini bukan kebocoran tetapi *ransomware* yang mengenkripsi seluruh arsip Rahasia, berapa lama waktu pemulihan? Apakah backup terenkripsi dan terpisah dari jaringan produksi? Kapan terakhir kali simulasi pemulihan dilakukan?
- Tindakan Perbaikan: Pastikan strategi 3-2-1 sudah diimplementasikan dan telah diuji melalui simulasi pemulihan dalam 6 bulan terakhir. Verifikasi bahwa backup tidak terjangkau oleh serangan yang sama dengan sistem produksi.

5.3 Pelajaran untuk Manajemen Atas

Studi kasus ini menunjukkan bahwa keamanan arsip adalah sistem terintegrasi. Kelemahan pada satu pilar akan menetralkan kekuatan pilar lainnya. RBAC yang tidak cukup detail (Pilar 1) menciptakan celah akses. Tanpa pemantauan audit trail yang aktif (Pilar 2), pelanggaran tidak terdeteksi secara dini. Tanpa kebijakan yang spesifik (Pilar 3), tidak ada dasar hukum untuk menindaklanjuti pelanggaran. Dan tanpa backup yang teruji (Pilar 4), dampak insiden yang lebih besar tidak dapat dipulihkan. Manajemen Atas harus memastikan keempat pilar ini dirancang, diimplementasikan, dan dimonitor secara bersamaan.

Output Portofolio

Refleksi Integrasi (Pilar 1 s.d. Pilar 4): Dengan merujuk studi kasus di atas, identifikasi minimal 2 celah keamanan yang berpotensi terjadi di unit Anda. Tentukan tindakan perbaikan untuk setiap pilar (Pilar 1 hingga Pilar 4), siapa yang bertanggung jawab atas implementasinya, dan berapa timeline penyelesaiannya.

Bab 6

Validasi, Portofolio & Executive Tollgate

6.1 Ringkasan Kriteria Penilaian

Tabel 6.1: Pemetaan Target Kompetensi → Kriteria Penilaian → Portofolio

Pilar	Target Kompetensi	Portofolio Wajib	Fokus Penilaian	Bobot
Pilar 1	Merancang skema kontrol akses RBAC terintegrasi dengan sistem kepegawaian	Matriks RBAC + Prosedur Akses	Kejelasan peran, least privilege, integrasi HR/SSO, review berkala	25%
Pilar 2	Merancang mekanisme audit trail otomatis yang merekam setiap akses dan perubahan arsip	Alur Audit + Template 14 Field	Kelengkapan 4W, immutability, compliance PP 71/2019 dan Perka ANRI 6/2021	25%
Pilar 3	Merumuskan kebijakan keamanan terintegrasi dengan ISMS organisasi	Rancangan Kebijakan Keamanan	Keselaran ISO 27001, Zero Trust, TARIF GCG	25%
Pilar 4	Merancang sistem backup dan disaster recovery terintegrasi	Matriks RTO/RPO + Rencana DR	Kesesuaian 3-2-1, target realistis, prosedur <i>fall-back</i> /simulasi	25%

Kelulusan: Skor portofolio ≥ 70 , post-test ≥ 65 , submit komitmen tindak lanjut.

6.2 Rubrik Penilaian Terukur

Tabel 6.2 hingga Tabel 6.5 memberikan indikator penilaian terukur untuk masing-masing portofolio, agar Manajemen Atas memiliki alat evaluasi yang objektif dan konsisten. Secara berurutan: Tabel 6.2 menilai Matriks RBAC (Pilar 1), Tabel 6.3 menilai Mekanisme Audit Trail (Pilar 2), Tabel 6.4 menilai Kebijakan Keamanan ISMS (Pilar 3), dan Tabel 6.5 menilai Sistem Backup & DR (Pilar 4).

6.3 Executive Tollgate Verifikasi

Sebelum implementasi, rancangan harus lolos 4 gate:

1. **GATE LEGAL:** Selaras PP 71/2019 & Perka ANRI 6/2021?
2. **GATE INTEGRITY:** Jamin keaslian via Hash + TTE + Audit Immutable?
3. **GATE VALUE:** Mitigasi risiko terkuantifikasi (*downtime* ↓, temuan audit → 0)?

Tabel 6.2: Rubrik Penilaian Portofolio 1 – Pilar 1: Kontrol Akses: Matriks RBAC Terintegrasi

Level	Indikator
Kurang (< 50)	Matriks peran tidak lengkap; tidak ada keterkaitan dengan sistem kepegawaian; prinsip <i>least privilege</i> tidak diterapkan; tidak ada prosedur <i>provisioning/de-provisioning</i> .
Cukup (50–69)	Matriks peran lengkap tetapi belum detail; keterkaitan dengan sistem kepegawaian disebutkan secara konseptual; ada prosedur tetapi belum operasional.
Baik (70–84)	Matriks peran lengkap dengan pemisahan hak akses yang jelas; prosedur <i>provisioning/de-provisioning</i> terhubung dengan siklus hidup kepegawaian; ada mekanisme review berkala.
Sangat Baik (≥ 85)	Seluruh indikator Baik terpenuhi, ditambah: validasi <i>segregation of duties</i> , mekanisme akses sementara (delegasi, lintas-unit), dan penanganan mutasi darurat sudah tercakup.

Tabel 6.3: Rubrik Penilaian Portofolio 2 – Pilar 2: Audit Trail: Mekanisme Audit Trail Otomatis

Level	Indikator
Kurang (< 50)	Tidak ada daftar event yang diaudit; 14 field metadata tidak lengkap; tidak ada penjelasan mekanisme immutability; tidak ada mekanisme eskalasi.
Cukup (50–69)	Daftar event ada tetapi tidak terstruktur; field metadata terisi sebagian; immutability disebutkan tetapi mekanisme tidak jelas; eskalasi bersifat umum.
Baik (70–84)	Kategori event lengkap dan terstruktur (akses, perubahan, persetujuan, ekspor, sistem); 14 field terisi lengkap; mekanisme immutability (hash chain/WORM) dijelaskan; ada prosedur eskalasi dengan timeline.
Sangat Baik (≥ 85)	Seluruh indikator Baik terpenuhi, ditambah: mekanisme alert otomatis untuk event kritis, retensi log sudah ditetapkan, dan kesesuaian dengan PP 71/2019 dan Perka ANRI 6/2021 dibuktikan.

Tabel 6.4: Rubrik Penilaian Portofolio 3 – Pilar 3: Kebijakan Keamanan: Kebijakan Keamanan Terintegrasi ISMS

Level	Indikator
Kurang (< 50)	Kebijakan tidak merujuk ISO 27001; tidak ada keterkaitan dengan ISMS organisasi; prinsip TARIF tidak terakomodasi; tidak ada analisis risiko.
Cukup (50–69)	Kebijakan merujuk ISO 27001 secara umum; ada keterkaitan dengan ISMS tetapi belum spesifik; sebagian prinsip TARIF terakomodasi; analisis risiko masih permukaan.
Baik (70–84)	Kebijakan selaras dengan minimum 3 kontrol ISO 27001 yang relevan; posisi kebijakan dalam hierarki ISMS jelas; seluruh prinsip TARIF terakomodasi; ada hasil analisis risiko sederhana.
Sangat Baik (≥ 85)	Seluruh indikator Baik terpenuhi, ditambah: mekanisme review berkala terjadwal, proses konsultasi internal terdokumentasi, dan klausul kepatuhan terhadap regulasi nasional (PP 71/2019, UU PDP) sudah spesifik.

Tabel 6.5: Rubrik Penilaian Portofolio 4 – Pilar 4: Pemulihan Data: Sistem Backup dan Disaster Recovery

Level	Indikator
Kurang (< 50)	Strategi backup tidak mengikuti 3-2-1; RTO/RPO tidak ditetapkan; tidak ada BCP; tidak ada prosedur fallback.
Cukup (50–69)	Strategi 3-2-1 disebutkan tetapi belum operasional; RTO/RPO ada tetapi belum berbasis BIA; ada draf BCP tetapi belum lengkap.
Baik (70–84)	Strategi 3-2-1 operasional; RTO/RPO berbasis klasifikasi arsip dan BIA sederhana; BCP mencakup prosedur <i>fallback</i> , prioritas <i>recovery</i> , dan jadwal simulasi.
Sangat Baik (≥ 85)	Seluruh indikator Baik terpenuhi, ditambah: jadwal simulasi terdokumentasi dengan hasil evaluasi, mekanisme komunikasi krisis, dan keterkaitan dengan ISMS (backup sebagai kontrol keamanan) sudah dijelaskan.

4. **GATE SCALE:** Infrastruktur & prosedur siap diskalakan jangka panjang?

Jika 1 gate bernilai No, lakukan perancangan ulang sebelum diajukan ke Komite Tata Kelola.

Glosarium

Berikut adalah daftar istilah teknis yang digunakan dalam modul ini, disusun secara alfabet untuk memudahkan referensi cepat:

ANRI	Arsip Nasional Republik Indonesia – lembaga pemerintah nonkementerian yang bertanggung jawab atas kebijakan dan penyelenggaraan kearsipan nasional.
Aset Informasi Kritis	Informasi yang kehilangan, kerusakan, atau pengungkapannya dapat menimbulkan dampak serius terhadap kelangsungan operasional, kepatuhan regulasi, atau reputasi organisasi.
Audit Trail	Jejak digital yang merekam setiap interaksi (akses, perubahan, persetujuan, ekspor) terhadap arsip secara kronologis, digunakan sebagai bukti akuntabilitas.
Backup	Pembuatan salinan data arsip yang disimpan secara terpisah dari data asli, untuk keperluan pemulihan jika terjadi kerusakan atau kehilangan data.
BCP	Business Continuity Plan – rencana terstruktur yang memastikan organisasi dapat melanjutkan fungsi bisnis kritis meskipun menghadapi gangguan besar.
BIA	Business Impact Analysis – analisis yang mengidentifikasi dampak ketidaktersediaan aset terhadap operasional, keuangan, dan kepatuhan, menjadi dasar penetapan RTO/RPO.
Break-Glass Procedure	Mekanisme akses darurat di luar hak akses normal, dengan pencatatan audit trail lengkap dan persetujuan atasan.
CRUD/CRU	Create, Read, Update, Delete – empat operasi dasar terhadap data. Dalam konteks arsip, sering ditulis CRU karena penghapusan (Delete) dibatasi.
DBA	Database Administrator – jabatan teknis bertanggung jawab atas pengelolaan dan keamanan basis data organisasi.
Device Trust	Verifikasi bahwa perangkat yang digunakan untuk mengakses sistem memenuhi standar keamanan organisasi sebelum akses diberikan.
Disaster Recovery (DR)	Proses dan prosedur untuk memulihkan sistem dan data arsip setelah terjadi bencana, bagian integral dari BCP.
DLP	Data Loss Prevention – teknologi yang memantau dan mencegah pengiriman data sensitif ke luar organisasi tanpa otorisasi.
Failover	Proses otomatis perpindahan operasional dari sistem utama ke sistem cadangan ketika terjadi gangguan, sehingga layanan tetap tersedia tanpa gangguan berarti.
GCG BUMN	Good Corporate Governance Badan Usaha Milik Negara – kerangka tata kelola yang mewajibkan BUMN menjalankan prinsip transparansi, akuntabilitas, responsibilitas, independensi, dan kewajaran.

Hash Chain	Mekanisme yang menghubungkan setiap entri log secara kriptografis, sehingga perubahan satu entri menyebabkan seluruh rantai berikutnya gagal verifikasi.
IAM	Identity and Access Management – sistem terpusat yang mengelola identitas pengguna, hak akses, dan autentikasi secara terintegrasi.
ISMS	Information Security Management System – sistem manajemen keamanan informasi berdasarkan standar ISO/IEC 27001 yang mencakup kebijakan, prosedur, dan kontrol keamanan.
IDS/IPS	Intrusion Detection System / Intrusion Prevention System – teknologi yang mendeteksi dan mencegah aktivitas jaringan yang mencurigakan.
Immutability	Sifat kekekalan data yang menjamin bahwa catatan yang telah dibuat tidak dapat diubah atau dihapus tanpa terdeteksi.
Klasifikasi Arsip	Pengelompokan arsip berdasarkan tingkat sensitivitas dan dampak keamanannya, umumnya dalam empat tingkat: Vital, Rahasia, Terbatas, dan Publik.
Least Privilege	Prinsip keamanan yang menyatakan bahwa setiap pengguna hanya boleh memiliki hak akses minimum yang diperlukan untuk menjalankan tugasnya.
MFA	Multi-Factor Authentication – autentikasi berlapis yang mengharuskan pengguna memberikan dua atau lebih bukti identitas (misalnya kata sandi + token).
Mirror Site	Pusat data cadangan yang menjadi replika identik dari sistem utama, siap mengambil alih operasional secara otomatis jika sistem utama mengalami gangguan total.
NAS	Network Attached Storage – perangkat penyimpanan data jaringan yang digunakan untuk menyimpan salinan backup arsip secara lokal dalam satu gedung atau area kantor.
NLP	Natural Language Processing – teknologi kecerdasan buatan yang menganalisis dan memahami teks secara otomatis, digunakan untuk membuat ringkasan isi dokumen arsip secara sistematis.
NIST	National Institute of Standards and Technology – lembaga riset dan standar Amerika Serikat yang menghasilkan kerangka keamanan siber praktikal (Cybersecurity Framework, SP 800-53, SP 800-207).
PDCA	Plan-Do-Check-Act – siklus perbaikan berkelanjutan yang menjadi fondasi ISO/IEC 27001:2022 untuk manajemen keamanan informasi.
PSTE	Penyelenggaraan Sistem dan Transaksi Elektronik – istilah resmi dalam PP 71/2019 yang mengatur kerangka hukum sistem elektronik di Indonesia.
Provisioning	Proses pemberian hak akses kepada pengguna saat penugasan baru, biasanya terintegrasi dengan sistem kepegawaian (SAP-HR/SSO).
RBAC	Role-Based Access Control – model kontrol akses berbasis peran di mana hak akses diberikan kepada jabatan/peran, bukan langsung kepada individu.

SAP	Systems, Applications, and Products in Data Processing – sistem perencanaan sumber daya perusahaan yang terintegrasi, digunakan PLN untuk mengelola kepegawaian, keuangan, dan operasional.
RPO	Recovery Point Objective – target jumlah data maksimum yang boleh hilang saat terjadi gangguan, diukur dalam satuan waktu mundur dari titik bencana.
RTO	Recovery Time Objective – target waktu maksimum yang dibutuhkan untuk memulihkan sistem setelah terjadi gangguan.
Segregation of Duties	Pemisahan fungsi yang memastikan tidak ada satu peran yang memiliki kombinasi hak akses berlebihan, untuk mencegah konflik kepentingan.
SIEM	Security Information and Event Management – sistem yang mengumpulkan dan menganalisis data log dari berbagai sumber untuk mendeteksi aktivitas mencurigakan.
SOP	Standar Operasional Prosedur – dokumen prosedur baku yang mengatur langkah-langkah operasional suatu aktivitas secara konsisten.
SRM	Senior Relationship Manager – jabatan manajerial senior di PLN yang bertanggung jawab atas hubungan strategis dengan pemangku kepentingan di tingkat unit induk.
TARIF	Transparansi, Akuntabilitas, Responsibilitas, Independensi, Fairness (Kewajaran) – lima prinsip tata kelola BUMN sebagaimana diatur dalam Permen BUMN PER-2/MBU/03/2023.
Tape Library	Sistem penyimpanan data menggunakan pita magnetik (magnetic tape) berkapasitas besar, digunakan untuk arsip atau backup jangka panjang dengan biaya penyimpanan rendah.
TTE	Tanda Tangan Elektronik Tersertifikasi – tanda tangan digital yang memiliki kekuatan hukum setara tanda tangan basah berdasarkan UU ITE.
VPN	Virtual Private Network – teknologi yang menciptakan jalur komunikasi terenkripsi antara pengguna dan jaringan organisasi, sehingga data aman dari penyadapan.
WORM	Write-Once-Read-Many – kebijakan penyimpanan di mana data hanya dapat ditulis sekali dan dibaca berulang kali, tidak dapat diubah atau dihapus.
Zero Trust	Prinsip arsitektur keamanan yang tidak memberikan akses default – setiap permintaan akses harus diverifikasi secara eksplisit berdasarkan konteks.

Daftar Pustaka

1. Peraturan Pemerintah Nomor 71 Tahun 2019 tentang Penyelenggaraan Sistem dan Transaksi Elektronik. Lembaran Negara Republik Indonesia Tahun 2019 Nomor 196.
2. Peraturan Arsip Nasional Republik Indonesia Nomor 6 Tahun 2021 tentang Pengelolaan Arsip Elektronik. Berita Negara Republik Indonesia Tahun 2021 Nomor 541.
3. ISO/IEC 27001:2022. *Information Security, Cybersecurity and Privacy Protection – Information Security Management Systems – Requirements*. International Organization for Standardization, Geneva.

4. ISO 22301:2019. *Security and Resilience – Business Continuity Management Systems – Requirements*. International Organization for Standardization, Geneva.
5. NIST. *Cybersecurity Framework 2.0*. National Institute of Standards and Technology, Gaithersburg, MD, 2024.
6. NIST SP 800-53 Rev. 5. *Security and Privacy Controls for Information Systems and Organizations*. National Institute of Standards and Technology, Gaithersburg, MD, 2020.
7. NIST SP 800-207. *Zero Trust Architecture*. National Institute of Standards and Technology, Gaithersburg, MD, 2020. <https://doi.org/10.6028/NIST.SP.800-207>
8. Sandhu, R.S., Coyne, E.J., Feinstein, H.L., & Youman, C.E. (1996). Role-Based Access Control Models. *ACM Computing Surveys*, 28(1), 65–79. <https://doi.org/10.1145/234513.234561>
9. Peraturan Menteri Badan Usaha Milik Negara Nomor PER-2/MBU/03/2023 tentang Pedoman Tata Kelola dan Kegiatan Korporasi Signifikan Badan Usaha Milik Negara.
10. World Bank. *Records Management Roadmap – Part 8: Resources dan Part 9: Implementation*. World Bank Group, Washington, DC, 2023.
11. The National Archives (UK). *Security Guidance for Archives and Records*. Kew, Surrey, 2023.
12. Veeam. (2024). 3-2-1 Backup Rule Explained. <https://www.veeam.com/blog/3-2-1-backup-rule.html>
13. PT PLN (Persero). Peraturan Direksi Nomor 0037.P/DIR/2022 tentang Organisasi dan Tata Kerja PT PLN (Persero). Jakarta, 2022.

Penutup

Keamanan & keterlacakan bukan hambatan operasional, melainkan pendukung akuntabilitas korporasi. Rancangan yang Anda susun dalam modul ini menjadi fondasi tata kelola arsip PLN yang tahan audit, patuh regulasi, dan siap mendukung transformasi digital kelas dunia.